

The Federation Strikes Back: A Survey of Federated Learning Privacy Attacks, Defenses, Applications, and Policy Landscape

JOSHUA C. ZHAO*, Purdue University, United States of America

SAURABH BAGCHI*, Purdue University and KeyByte, United States of America

SALMAN AVESTIMEHR, University of Southern California and FedML, United States of America

KEVIN S. CHAN, DEVCOM Army Research Laboratory, United States of America

SOMALI CHATERJI, Purdue University and KeyByte, United States of America

DIMITRIOS DIMITRIADIS, Amazon, United States of America

JIACHENG LI, Purdue University, United States of America

NINGHUI LI, Purdue University, United States of America

ARASH NOURIAN, Amazon, United States of America

HOLGER R. ROTH, NVIDIA, United States of America

Deep learning has shown incredible potential across a wide array of tasks, and accompanied by this growth has been an insatiable appetite for data. However, a large amount of data needed for enabling deep learning is stored on personal devices, and recent concerns on privacy have further highlighted challenges for accessing such data. As a result, federated learning (FL) has emerged as an important privacy-preserving technology that enables collaborative training of machine learning models without the need to send the raw, potentially sensitive, data to a central server. However, the fundamental premise that sending model updates to a server is privacy-preserving only holds if the updates cannot be "reverse engineered" to infer information about the private training data. It has been shown under a wide variety of settings that this privacy premise does *not* hold.

In this survey paper, we provide a comprehensive literature review of the different privacy attacks and defense methods in FL. We identify the current limitations of these attacks and highlight the settings in which the privacy of an FL client can be broken. We further dissect some of the successful industry applications of FL and draw lessons for future successful adoption. We survey the emerging landscape of privacy regulation for FL and conclude with future directions for taking FL toward the cherished goal of generating accurate models while preserving the privacy of the data from its participants.

CCS Concepts: • **Security and privacy** → **Human and societal aspects of security and privacy, Systems security**; • **Computing methodologies** → *Machine learning*.

*Other than the first two authors, all other authors are listed alphabetically. Corresponding author: Saurabh Bagchi.

Authors' addresses: Joshua C. Zhao*, Purdue University, West Lafayette, IN, United States of America, zhao1207@purdue.edu; Saurabh Bagchi*, Purdue University and KeyByte, West Lafayette, IN, United States of America, sbagchi@purdue.edu; Salman Avestimehr, University of Southern California and FedML, Los Angeles, CA, United States of America, avestime@usc.edu; Kevin S. Chan, DEVCOM Army Research Laboratory, Adelphi, MD, United States of America, kevin.s.chan.civ@army.mil; Somali Chaterji, Purdue University and KeyByte, West Lafayette, IN, United States of America, schaterji@purdue.edu; Dimitrios Dimitriadis, Amazon, Bellevue, WA, United States of America, dbdim@amazon.com; Jiacheng Li, Purdue University, West Lafayette, IN, United States of America, li2829@purdue.edu; Ninghui Li, Purdue University, West Lafayette, IN, United States of America, ninghui@purdue.edu; Arash Nourian, Amazon, Sunnyvale, CA, United States of America, nourian@gmail.com; Holger R. Roth, NVIDIA, Bethesda, MD, United States of America, hroth@nvidia.com.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than ACM must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

© 2025 Association for Computing Machinery.

Manuscript submitted to ACM CSUR

Manuscript submitted to ACM CSUR

1

Additional Key Words and Phrases: Distributed machine learning, Federated learning, Privacy in federated learning, Application domains for federated learning, Privacy policies

ACM Reference Format:

Joshua C. Zhao*, Saurabh Bagchi*, Salman Avestimehr, Kevin S. Chan, Somali Chaterji, Dimitrios Dimitriadis, Jiacheng Li, Ninghui Li, Arash Nourian, and Holger R. Roth. 2025. The Federation Strikes Back: A Survey of Federated Learning Privacy Attacks, Defenses, Applications, and Policy Landscape. *ACM Comput. Surv.* 1, 1 (March 2025), 35 pages. <https://doi.org/10.1145/3724113>

1 Introduction

Federated Learning (FL) is a popular learning paradigm that allows one to learn a Machine Learning (ML) model collaboratively. The classical structure of FL is with multiple clients each having their own local data, which they would possibly like to keep private, and there is a server that is responsible for learning a global ML model.¹

One of the two primary reasons for the popularity of FL is that clients can keep their data private and still benefit from the combined learning across all of their data. (A second reason is the “power of crowds”, i.e., many weak devices can come together to learn complex models, which would be beyond the compute power of any one client to learn on its own.) However, by 2018, the privacy of FL has been put into question. In a set of seminal papers, it was shown that a central aggregator with access to gradients sent by the clients (which is standard in most versions of FL), then the aggregator can learn various things from these clients, each of which would be taken to effectively break the privacy of client data. [93, 147, 152] The simplest form of this attack is where the aggregator can reconstruct the data of the clients from the gradient updates, to different degrees of fidelity. The attacker, the central aggregator here, has the unique advantage that it can observe individual updates from the clients over time and can control the view of the participants of the global parameters. Also worryingly, the attacker can even be one of the clients who can observe the global parameter updates, and can control his parameter uploads [66].

In this article, we survey the constant back and forth that has been roughly going on for the last 5 years in protecting the privacy of data through FL. We will have as one of the primary focus questions: what are the research challenges that need to be solved to achieve “good enough” protection for different application use cases. Our article takes a distinctive viewpoint of grounding the technical discussion of the attacks and the defenses in application use cases. For example, the kind of privacy expectation, and regulation, in the healthcare sector is very different from that in the finance or insurance sector, which again is distinct from that in Internet of Things (IoT).

We provide a categorization of the attacks against privacy in FL (Section 6) and also a categorization of the defenses (Section 7). A coupled dimension is the kind of FL that is happening — cross-device vs. cross-silo, horizontal FL vs. vertical FL, or derivatives of classical FL, such as, peer-to-peer learning or hierarchical FL. The discussion of attacks and defenses is meaningful only when we provide the context of what the threat model is, i.e., what are the capabilities available to the adversaries and to the defenders, what aspect of the learning process is attacked (model, data, or something else), and what is the proportion of benign vs. adversarial entities. We provide this kind of foundation-setting discussion in Section 2.

Policy considerations. Our article goes beyond the technology landscape and also surveys the policy landscape (Section 5), which is still developing. A central consideration of ML regulation, namely, regulation of the data, is central to FL since here we deal with data that is local, and possibly sensitive, to individual clients. Regulation of FL is therefore

¹The phrase “The Federation Strikes Back” is a playful nod to the *The Empire Strikes Back*, symbolizing the ongoing arms race between privacy attackers and defenders in the federated learning domain, where data confidentiality stands at the heart of the conflict.

important and a start needs to be made soon. We hope that this discussion of regulation, in the context of the technical achievements to date and the expected deliverables, will lead to better regulation in the space of privacy in FL.

Privacy pushes-and-pulls. Given that being a privacy-preserving technology was a core reason for its introduction, it is vital that FL is indeed able to preserve the privacy of users. However, the process of sending gradients or model updates to a server has been shown to be less than secure. Recent works in membership inference, property inference, and even data reconstruction have demonstrated that vanilla FL is vulnerable to a multitude of privacy attacks. Defenses such as **secure aggregation, differential privacy, or homomorphic encryption** have also continued to be developed to prevent these attacks. Ultimately, the privacy expectation of FL is that an attacker, whether it is the server, an outsider, or a participating client, is not able to infer any private information about the local training data of any of the clients. In this work, we discuss current privacy attacks and pinpoint the vulnerabilities that make them possible. We then highlight the defenses that can prevent the attacks or make them more difficult along with the limitations and drawbacks of each.

2 Problem Context

2.1 Federated learning process

FL has emerged as a decentralized training framework that addresses the dual challenges of leveraging computational resources at the network’s edge and preserving data privacy. Central to FL is its unique approach to collaborative model training, which aggregates model updates from participating clients rather than transmitting the raw data of the clients. This method not only leverages the vast computational power distributed across edge devices but also aligns with the increasing demands for data privacy amidst the exponential growth and insatiable appetite for data of modern AI systems. At the heart of FL is the distributed training of machine learning models, where the crux lies in the *exchange of model updates* with a central server, sidestepping the need to share sensitive training data.

The vanilla FL training process typically involves the coordinated interplay of two principal actors: the central server and the participating clients. The central server orchestrates the workflow by selecting the clients, dispatching the global model to the participating clients for local refinement, and then aggregating the updates before finally updating the global model again. Conversely, clients engage in a straightforward yet crucial role. They receive the global model from the server, apply training updates using their local datasets, and then transmit their updates back to the server.

For an FL training cycle, the operations unfold as follows:

- (1) **Client Selection and Model Dispatch:** The central server selects a subset of k out of N available clients, dispatching the current global model parameters, G_t , to them. The selection count varies based on the FL scenario:
 - In *cross-device FL*, typically involving lightweight devices like smartphones or IoT devices, the selection ranges from 100s to 1000s. Device communication and computation are typically more unreliable.
 - In *cross-silo FL*, involving entities like data centers or hospitals, a tighter group of 5–10 clients is chosen, reflecting the higher trust, collaboration levels, and substantial computational resources of these participants.
- (2) **Local Training and Update Generation:** Participating clients refine the global model G_t using their local data across one or more iterations. This process yields updates, either as computed gradients, $\nabla G_{t,i}$, or direct model parameter modifications, which are then sent back to the central server.
- (3) **Aggregation and Global Model Update:** The server aggregates these client updates using methods such as a weighted mean or other aggregation method to form the new global model parameters, $G_{t+1} = G_t + \sum_{i=1}^k (w_i \cdot \nabla G_{t,i})$. This prepares the model for the next distribution, refinement, and aggregation cycle.

- (4) This iterative process repeats until satisfactory model performance is reached, i.e., convergence is reached to a reasonable degree.

2.2 Enhancing Federated Learning: Key Considerations for Operational Integrity and Security.

Several additional considerations come into play, ensuring the smooth and secure operation of this collaborative model training process. Here are some of the important considerations.

Client eligibility and selection: One of the initial steps in the FL cycle involves the selection of participating clients. In scenarios categorized under cross-device FL, where the participants are typically mobile or IoT devices, certain prerequisites must be met before a device is deemed eligible. These prerequisites often include having sufficient battery life to complete the training tasks without interruption and a stable network connection to facilitate seamless communication with the central server. These criteria are essential to prevent dropout or delays in the training process.

Security enhancement through encryption: Once selected and during the model refinement phase, enhancing security becomes paramount. To this end, clients may employ encryption techniques to the updates they generate. This encryption ensures that the gradients or model parameter modifications are securely transmitted to the central server, safeguarding the data against eavesdropping or tampering attempts. This layer of security is crucial in preserving the integrity of the data and the privacy of the clients' information.

Robust aggregation by the central server: The central server plays a critical role in aggregating the updates from all participating clients. Given the potential for compromised devices or malicious actors within the network, the server might implement robust aggregation techniques [113, 114]. These techniques are designed to identify and neutralize the influence of any anomalous updates that could skew the model's learning in an undesirable direction. By employing such strategies, the server ensures that the aggregated update accurately reflects the collective learning from all legitimate participants, thereby reinforcing the reliability and effectiveness of the process.

2.3 Variants of Federated Learning

2.3.1 Cross-device and Cross-silo Federated Learning: FL can be broadly categorized into cross-device and cross-silo contexts, each presenting unique scalability and deployment challenges. Cross-device FL typically operates with a vast network of personal devices, such as smartphones, wearables, or IoT devices, each participating in the learning process. This variant is marked by its massive scale, involving potentially *millions of devices*, each contributing data for model training. The finance sector, for example, could leverage FL to enhance fraud detection systems by learning from transactions across countless mobile banking apps without centralizing sensitive financial data. However, cross-device FL still has many challenges, primarily due to the limited computational power and intermittent connectivity of devices, not to mention the heightened concerns over data privacy and security.

Conversely, cross-silo FL operates on a smaller scale with fewer, resource-ample entities like hospitals, featuring stable communications and higher computational resources. In healthcare, for instance, cross-silo FL enables hospitals to collaboratively improve diagnostic models by learning from diverse patient datasets while ensuring that sensitive medical records remain within hospital premises. Similarly, in finance, banks can utilize cross-silo FL to jointly develop more accurate credit scoring models without exposing their clients' financial details to competitors. This form of FL, while offering more control and resources, still necessitates careful navigation of regulatory, privacy, and interoperability challenges. We discuss the applications of various privacy-preserving defenses for each category in-depth in Section 7.

2.3.2 Federated transfer learning: Federated Transfer Learning (FTL) extends FL by facilitating knowledge sharing across different domains or tasks, aiming to enhance model performance where direct data sharing is infeasible. Unlike FL, which focuses on aggregating updates to refine a global model, FTL emphasizes transferring knowledge from a well-resourced source domain — rich in labeled data — to a target domain with limited labeled resources. This cross-domain learning is achieved by sharing model parameters or learned features instead of raw data, thus inherently supporting privacy by keeping the data localized while only model information traverses domains.

FTL is particularly useful in scenarios where data cannot be pooled together due to privacy concerns but where tasks across domains are related. For example, in healthcare, models trained on patient data from one hospital on one task can be adapted to improve predictions in another hospital on a different task, despite differences in patient demographics or data collection practices. Similarly, in finance, the knowledge from credit scoring models in one region can be transferred to enhance models in another region.

2.3.3 Hierarchical Federated Learning Hierarchical Federated Learning (HFL) [20, 28, 53, 86, 87] introduces a multi-tiered aggregation framework, significantly enhancing the scalability and efficiency of collaborative learning models. This system incorporates several levels of servers, from edge parameter servers to a final cloud parameter server, facilitating a more structured and efficient communication and aggregation pathway. By leveraging edge servers for initial aggregation [86], HFL mitigates the communication bottlenecks often encountered in traditional FL, enabling faster, more energy-efficient training processes. In response to the limitations observed in both FL and P2PL — where FL’s centralized model can pose privacy risks, and P2PL’s decentralized nature complicates integrity and consensus — HFL emerges as a powerful hybrid solution. It employs a hierarchical structure in which clients communicate updates to edge servers which then aggregate these updates before further communication among themselves or with a higher-level server. This architecture not only reduces the privacy concerns associated with a single central server but also addresses the communication and consensus challenges inherent in a fully decentralized setup.

2.3.4 Horizontal and Vertical Federated Learning In FL, data can be partitioned in two primary ways: horizontally or vertically. This distinction significantly impacts the learning process and the approach to privacy and efficiency in collaborative learning environments. Horizontal Federated Learning involves clients that have data sharing the *same feature space* but differ in the *samples* or *IDs*. This is common in scenarios where different entities collect similar types of data across various subjects.

Example: Consider multiple hospitals collecting health data. Each hospital has its own set of patient data, with the feature space (types of health data) being consistent, but the actual data (patient records) varying. Mathematically, this can be represented as:

Let D_i and D_j be datasets from hospitals i and j respectively, where (1)

$$D_i, D_j \subseteq \mathcal{X} \times \mathcal{Y}, \quad \text{and} \quad \mathcal{X}_i = \mathcal{X}_j, \quad \text{but} \quad \mathcal{Y}_i \neq \mathcal{Y}_j \quad (2)$$

Vertical Federated Learning involves clients that have data with the *same IDs* but inhabit different *feature spaces*. This setup is typical in collaborations between entities that collect different types of data about the same subjects.

Example: A bank and a hospital share data about the same individuals, with the bank holding financial information and the hospital holding medical records. They share IDs but have vastly different feature spaces.

Let D_a from a bank and D_b from a hospital, where (3)

$$D_a, D_b \subseteq \mathcal{X} \times \mathcal{Y}, \quad \text{and} \quad \mathcal{Y}_a = \mathcal{Y}_b, \quad \text{but} \quad \mathcal{X}_a \neq \mathcal{X}_b \quad (4)$$

2.3.5 Data Distribution Attributes and Differences **IID Data Distributions:** In scenarios where data is considered IID, each client’s dataset is assumed to be drawn from the same probability distribution. This uniformity suggests that datasets across varied domains, such as those of a bank and a hospital, exhibit similar statistical properties and structures, despite their distinct contexts. **Non-IID Data Distributions:** On the other hand, non-IID data distributions reflect situations where data across clients originate from heterogeneous distributions. This diversity is rooted in demographic variances, regional characteristics, or the intrinsic nature of the collected data.

2.3.6 FedSGD and FedAvg: Core FL algorithms The two standard FL algorithms are FedSGD and FedAvg [91], mainly differ in the number of local iterations. FedSGD, the federated adaptation of stochastic gradient descent, operates on the principle of minimalism. It mandates that clients engage in a singular iteration of training on a localized data batch before transmitting the resultant gradient to a central server. This server, in turn, aggregates the gradients from all participating clients, adjusting the weights in proportion to each client’s contribution to the total dataset.

Advancing beyond FedSGD, FedAvg introduces multiple local iterations and/or epochs at each client before communicating updates to the server. These updates can comprise either the computed gradients over all local iterations or the updated model parameters themselves. The algorithm structure inherently minimizes the frequency of communication with the server, but also helps with privacy concerns by limiting the server exposure to initial and final model states only. This characteristic is surprisingly helpful in contexts where data sensitivity is paramount, as it effectively conceals the intermediate computational states from potential attackers.

2.4 Technical Challenges for Federated Learning

Federated learning expects computational and bandwidth resources to fully leverage the private data. Multiple federated learning algorithms have proposed solutions for efficient communication and/or compute resource scarcity. However, most of the deployed platforms are not built to address such requirements, making them the wrong choice for seamless, scalable federated learning. These platforms are often limited in resources, competing with other onboard functionalities, making scheduling an additional challenge. Earlier solutions were performing federated learning computations when the devices were idle, during the night and plugged in a power outlet. However, this can create biased models, where some of the data distributions are largely ignored.

2.4.1 Implications on Security of the Learning Federated Learning introduces Security risks mainly for two reasons: the private data cannot be audited or curated, enabling “bad actors” to alter their data according to the end-goal, i.e. “training data attacks”. Also, the models are exposed during the communication process, introducing security risks while providing opportunities for backdoor attacks. These attacks aim at “influencing” the model parameters to a particular behavior, or simply degrading the overall model performance.

2.4.2 Data and Device Heterogeneity Data and device heterogeneity can lead to biased models. The private data distributions and the available computational resources can vary widely between different clients, which leads to issues such as global model drift or the need to adopt multiple model architectures. FedAvg often shows performance disadvantages to highly mismatched data distributions, and several approaches have been proposed to address this issue. Besides any mismatch between distributions, the lack of labels during training can also produce suboptimal training conditions. This problem can be either mitigated by Knowledge Distillation [37], heuristics [133] or asking users to label their data [22]. A basic assumption of the early FL algorithms was the local model structure is uniform across all clients. However, clients can differ in their computational resources and data distributions.

2.5 Threat model

For privacy attacks within the domain of FL, the threat landscape is complex and varies significantly based on the nature of the attack. The architecture of FL inherently poses unique challenges in safeguarding privacy due to the decentralized nature of data processing. Understanding the nuances of these threats is crucial for developing robust defense mechanisms. At the heart of FL, the central server embodies a critical point of vulnerability. It plays a dual role: distributing the learning model to clients and aggregating their updates. This centralized control positions the server as a potent target for attacks, making it the focal point for the strongest privacy threats in FL. This is split into two broad types of threats as follows:

Central Server Threats: *Honest-but-Curious Server:* This scenario presupposes a server that adheres strictly to the prescribed FL protocol without any malicious alterations. However, it harbors intentions to infer private information from the updates received from clients. Despite its non-intrusive facade, this model represents a significant privacy threat as the server possesses the capability to analyze aggregated data and potentially extract sensitive client information without overtly compromising the integrity of the training process.

Malicious Server: A more daunting threat emerges with the malicious server, which actively seeks to undermine the privacy and integrity of the FL process. This adversary is not bound by the ethical constraints of the honest-but-curious model and may engage in manipulative tactics such as altering client model parameters, tweaking the model architecture, or distorting the training process. The objective is clear: to siphon off private data from clients or to inject biases into the model, thereby compromising both privacy and model fidelity.

Client-Side Threats: A parallel threat model arises due to the clients. Corresponding to the server case, here also the clients can be: *Honest-but-Curious Clients:* Parallel to the server-side threat, clients under this model operate within the bounds of the FL protocol but with ulterior motives. They aim to intercept and analyze communications between other clients and the server, with the ultimate goal of reconstructing the local data of their peers. This form of eavesdropping introduces a subtle yet potent risk to data confidentiality within the FL ecosystem.

Malicious Clients: Beyond mere curiosity, malicious clients actively engage in sabotaging the FL process. By submitting falsified updates, these adversaries attempt to derail the collective learning effort, leading to a degraded model utility. While this behavior does not directly infringe on privacy, it undermines the integrity and reliability of the FL system, posing a significant challenge to maintaining model quality.

Complexities of Misbehaving Clients: The threat landscape is further complicated by the variability in the behavior of misbehaving clients. Two critical factors need consideration: the proportion of clients engaged in malicious activities and the extent of their collaboration. Misbehaving clients may operate independently, presenting a scattered threat. However, the danger amplifies when they collude, orchestrating their attacks to maximize disruption or data extraction. This coordinated effort can significantly exacerbate the challenges in defending against privacy breaches and ensuring the integrity of the FL process [113].

2.6 Metrics measuring privacy

Membership inference attacks - accuracy. The goal of membership inference attacks is to infer whether a particular instance is used in the training of a target model. A balanced evaluation set, which consists of the same number of members and non-members, is used by the membership inference attack evaluations in most existing literature. For membership inference attacks, the attack accuracy measures the attack effectiveness over the whole data population [116].

Attack AUC can also be used to measure the privacy leakage in terms of membership inference over the whole population. The higher the attack accuracy is, the more privacy leakage the target model has on its training set for the whole set.

Membership inference attacks - TPR at a low FPR. Accuracy and AUC measures the average privacy vulnerability across all instances. In the context of privacy, one usually wants to ensure that every individual's privacy is protected. It is thus necessary to measure membership leakage threat for the most vulnerable instances. In [29], it was proposed to use true positive rate (TPR) at a low false positive rate (FPR) to measure effects of MI attacks. Consider, for example, TPR at FPR= 0.001. If TPR is also around 0.001, then that means the adversary cannot do better than random guessing even when they are very confident about MI inference. On the other hand, if TPR is around 0.01, then an adversary would be able to correctly identify (a small percentage of) members with a 10 : 1 odds ratio.

Data reconstruction attacks - reconstruction quality. One important metric for gauging the success of data reconstruction attacks is in the similarity of the reconstructions to the ground truth images. This measure can be visual and is typically quantified through image similarity metrics such as PSNR (peak signal-to-noise ratio), SSIM (structural similarity index measure), or L-PIPS (learned perceptual image patch similarity). Image identifiability precision (IIP) was also introduced as a potential metric for reconstruction quality [139]. Instead of per-image calculations, compared to all images in the ground truth batch, IIP finds the nearest neighbor of each reconstructed image. The metric is quantified as the fraction of reconstructions that have the ground truth image as their nearest neighbor. Additionally, [148] discusses the use of leaked data for training models in downstream prediction tasks related to the image similarity metrics, where even reconstructed images with the lowest metric scores (e.g., PSNR < 12, SSIM < 0.2) were still shown to improve the accuracy of trained models [148].

Data reconstruction attacks - leakage rate. Another metric used to quantify success of data reconstruction attacks is leakage rate. While leakage rate can be simply defined as the number of leaked images, quantification can still vary. Some methods, such as linear layer leakage, can result in leaking an image consisting of multiple client images overlapping. Here, leakage rate is typically defined as the number of reconstructions with only have a single, non-overlapping image leaked. Although methods such as gradient inversion typically rely on image similarity to measure quality, leakage rate can also be used based on the number of images above a given threshold for any metric (e.g., PSNR > 16) [63].

3 Relation to Prior Surveys

Federated learning was originally introduced as a method to collaboratively train machine learning models while allowing users to keep their data local and private. Despite this, many prior works have shown that the updates sent to a server still inherently include sensitive information that can be used to leak either properties of the data or reconstruct them directly. Following this, much work has also been done in the area of FL privacy defense. To motivate our work, we first compare the prior surveys in FL privacy and discuss the missing pieces. Table 1 shows a summary of previous surveys compared to this work.

Many surveys have looked at the privacy aspect of FL. The works of [49, 75, 85] discuss privacy defense in FL with little discussion on privacy attacks. Other surveys [27, 34, 88, 95, 117, 140, 145] look at privacy attacks, but are missing discussion on more recent catastrophic attack methods such as linear layer leakage for data reconstruction or membership inference attacks that do not require training data. Chen et al. [31] discusses the trade-off between privacy and fairness in FL. While the methods of optimization and closed-form linear layer leakage attacks are discussed, the work still misses other key data reconstruction methods such as multi-round disaggregation or attacks targeted against secure aggregation. Similarly, Rigaki and Garcia [108] discusses privacy attacks in machine learning but also lacks many

Table 1: Comparison of federated learning privacy surveys

References	Privacy		Industry	
	Defenses	Attacks	Applications	Policy
Li et al [85]	✗			
Ouadrhiri et al [49]	✗			
Chen et al [31]	✗	✗		
Lyu et al [89]	✗	✗		
Rigaki et al [108]	✗	✗		
Our work	✗	✗	✗	✗

current privacy attacks specific to FL. Lyu et al. [89] is the closest survey to ours, focusing on security and privacy attacks and defenses in FL. However, important discussion on the key limitations of attacks and defenses is missing. Similarly, recent, powerful data reconstruction attacks such as [55, 74, 80, 135] are missing.

Our work bridges this gap on the recent and rapid development of privacy attacks and defenses and provides a comprehensive discussion on current privacy threats (data reconstruction, membership-inference, and property inference attacks) and defenses (differential privacy, secure aggregation, homomorphic encryption, and trusted execution environments) while highlighting the limitations of these methods along with areas where improvement is needed. Additionally, to the best of our knowledge, we are the only work that discusses current industry applications utilizing FL in a variety of industry sectors including healthcare, finance, and IoT edge applications. Similarly, we are the only work to include crucial discussion on government data privacy policies and their relation to FL. We close our work by looking ahead and hypothesizing the key developments that would be necessary for FL to become a privacy-preserving technology that addresses user privacy concerns and policy mandates in real-world deployments.

4 Application Use Cases and Policy Drivers

Federated learning has multiple applications across various industries, including healthcare, finance, automotive, and IoT/Edge devices. In healthcare, FL can be used to train models on patients' data without compromising privacy, especially when using differential privacy. Similarly, in the financial industry, we can employ FL to train fraud detection models without exposing sensitive financial data to potentially malicious entities. In the automotive industry, FL can be employed to train autonomous driving models on real-life data while avoiding the costs of transferring huge volumes of data back to the servers. Table 2 further summarizes the application domains along with the commonly applicable setting (cross-device and cross-silo) for deployment.

FL has been successfully deployed in industry settings [59] [19] [144] [125]. One example of successful adoption comes from predictive maintenance and failure prediction, which are crucial for large-scale production lines. They require real-time failure monitoring and updates from multiple resources across an enterprise that are often guarded by different privacy and security policies. Bosch [59] has used many federated algorithms in various horizontal FL and vertical FL production scenarios such as predictive maintenance. Through this, Bosch was able to improve the life expectancy of production line machinery over time without significant overhead compared to centralized learning approaches. Other companies [19] have also used FL in similar use cases to drastically reduce the cost of halting in the production line due to unexpected failures.

Table 2: Characterization of federated learning application domains into cross-device and cross silo deployments

Application Domain	Cross-Device	Cross Silo
Healthcare	✓	✓
Finance		✓
IoT / Edge	✓	✓
Autonomous Driving	✓	

4.1 Application of FL in Healthcare

Over the past few years, the automation of the healthcare industry has surged, driving an increasing demand for advanced ML models. Healthcare professionals are leveraging technology to enhance patient care and better meet emerging global demands while managing vast and sensitive datasets. Training effective healthcare models, however, requires access to diverse data sources, and sharing such information is increasingly challenging under strict privacy regulations. FL offers a promising solution by enabling collaborative model training across institutions without exposing sensitive local data. With FL, participating organizations can develop a global model based on their in-house data, leading to more accurate and diverse ML models [39] while complying with regulatory frameworks and mitigating data silo issues.

Several real-world efforts have been made around FL in the healthcare sector, including proof-of-concept projects and the establishment of long-running consortia [106, 107]. For example, in the United Kingdom, the FLIP project empowers AI researchers to develop clinical applications using NHS patient data without transferring the information outside the hospital network, thus addressing the challenge of confidentiality in healthcare [6]. In France, the HealthChain consortium [13] aims to address the bottleneck in accessing medical data for AI models that could lead to medical breakthroughs. In Germany, the Trustworthy Federated Data Analytics (TFDA) project [17] aims to address the challenges posed by centralized data structures in the context of growing need for more data for machine learning. Recognizing the drawbacks and threats associated with data centralization, TFDA focuses on implementing decentralized cooperative data analytics architectures, specifically within and beyond the Helmholtz research community.

The MELLODDY project [65, 99], co-funded by the European Union and EFPIA companies, has successfully demonstrated the feasibility of large-scale collaborative artificial intelligence (AI) for drug discovery. By leveraging a large collection of small molecules, the project utilized federated and privacy-preserving machine learning to achieve more accurate predictive modeling, leading to potential efficiencies in drug discovery. The German Cancer Consortium’s Joint Imaging Platform (JIP) [112] is a strategic initiative within the German Cancer Consortium (DKTK) with the goal of establishing a technical infrastructure to facilitate modern and distributed imaging research. Emphasizing the use of contemporary machine learning methods in medical image processing, the project aims to enhance collaboration among clinical sites and support multicenter trials. Internationally, the Federated Tumor Segmentation (FeTS) initiative [8, 103] is developing one of the largest federations of healthcare institutions. This initiative aims to gain knowledge for tumor boundary detection from diverse patient populations without sharing patient data.

In a collaborative effort involving seven clinical institutions worldwide, an early study explored using FL to construct robust medical imaging classification models for breast density based on BI-RADS [109]. Despite significant differences in datasets across sites, including mammography systems, class distribution, and data set size, the results demonstrated successful AI model training in a federated manner. The EXAM project [41] aimed to build a common predictive model to estimate the oxygen treatment requirements of patients arriving at the emergency department (ED) with symptoms of COVID-19 for the next 24h and 72h periods. A consortium of 20 hospital sites across the globe participated in

this real-world application of FL. Furthermore, institutions such as The American College of Radiology (ACR) enable privacy-preserving AI utilizing FL technology [15].

The concept of federation has deep roots in computational genomics [30]. Early work on federating computational resources—such as CPUs, GPUs, and FPGAs—and datastores demonstrated that distributed processing within unified portals could simplify data management and minimize extensive data transfers. This pioneering research remains relevant today by enabling the efficient handling of large-scale genomic data while ensuring privacy and security, paving the way for advanced federated approaches in healthcare. In particular, the seminal work on federated compute infrastructures for genomics highlights challenges such as heterogeneous data formats and disparate computational environments. By standardizing data exchange protocols and developing interoperable interfaces, early federated systems achieved seamless integration of diverse resources and minimized the need for large-scale data transfers. These innovations not only enhanced data security through localized processing and robust access controls but also laid the groundwork for overcoming technical and regulatory barriers—a legacy that informs and strengthens current FL applications in healthcare. Furthermore, computer systems research toward optimizing databases such as SOPHIA [90] has leveraged these federated principles to tackle dynamic workload challenges in real-world settings. The SOPHIA framework optimizes the reconfiguration of clustered NoSQL databases for applications like MG-RAST—a global-scale metagenomics repository—thereby ensuring high throughput and data availability despite fluctuating workloads. This integration of federated techniques with adaptive database management demonstrates how cross-silo federation can enhance scalability, performance, and resilience in modern database systems, making it a critical enabler for both computational genomics and healthcare applications.

An example of cross-device federated learning in the healthcare setting is action recognition performed on heterogeneous embedded devices [70]. In healthcare, such methods can be applied to patient monitoring tasks, including fall detection or tracking physical activity during rehabilitation. Each device processes its local sensor or video data and contributes to a collaboratively trained global model without sharing raw data. This approach effectively addresses the challenges posed by devices with varying computational capabilities. In particular, asynchronous federated optimization allows each device to send its model updates to the server as soon as its local training is complete, rather than waiting for a synchronized round. This reduces idle time and mitigates the straggler problem—where slower devices hold back the overall training progress—thus accelerating the training process while maintaining robust model convergence.

4.2 Application of FL in Finance

The data privacy and protection laws are becoming ever more restrictive, especially in industries like the Financial sector. This allows consumers and businesses to trust each other to keep the data safe and secure. With traditional ML, businesses dependent on FinTech face several issues, such as getting clearance and lawful consent, the governance of the customers' data, and finally, the cost in collecting and of managing such data. FL provides an efficient way for managing this data by keeping it local, on the financial institutions servers. FL is an encrypted and distributed machine learning approach that allows joint training on decentralized data where participants do not need to share it.

One of the most promising applications in financial services is anti-money laundering (AML). In a typical money laundering scheme, criminals try to conceal the origin, identity, and destination of financial transactions to look normal as they are from a legitimate source. AML solutions allow financial institutions to prevent, detect, investigate and report any activity that is suspicious of money laundering and stop criminals from illegally obtained funds as legitimate income. The estimated amount of money laundered globally in one year is 2 - 5% of global GDP (\$800 billion - \$2 trillion) [18]. Failure to prevent money laundering can endanger the integrity and stability of global financial system.

Financial institutions are required to put strict policies and measures to prevent, detect, and report laundered money and combat these crimes. However, each financial institution typically only has access to its own transnational data and can not prevent and detect complex money laundry cases where money routed through multiple financial institutions could look legitimate to individually involved institutions in the chain. Cross-silo Federated AML can greatly help financial institutions to create better predictive models with broader context for identifying bad actors. Such models learn more global and deeper correlation identifiers for bad actors and money laundering specific actions based on contributed data provided by a consortium of financial institutions.

Another application of FL is in insurance underwriting. The main use cases of FL in insurance include origination-predicting if a person contracts an insurance offer, insurer's risk assessment, fraud detection, and claim processing. Due to soiled data in different companies on different demographics or customers movement across insurance companies, insurers can significantly improve their predictive models for these use cases by utilizing FL. Claim history processing is of the most challenging use cases that can lead to more accurate and efficient operations. Insurance companies often need to have access to previous claims history of an insurer in details to give a better pricing or benefits to new clients. However, having access to such historical data in a privacy preserving manner is challenging due to regulations governing the insurance industry. Insurance companies can leverage cross-silo FL to privately train their models without compromising customers privacy and satisfying the governing regulations. Such models lead to more accurate offers while helping customers get the benefits of having a long-term history of free claims across different categories.

4.3 Application of FL in IoT or at the Edge

The Internet of Things (IoT) is the current concept of ubiquitous internet connectivity of all devices (refrigerators, toasters, doorbells, street cameras, ..., the list is unending). As the data from these devices scan come from anywhere, the privacy and security of these devices and the data is paramount. However, there is strong interest from companies and individuals to exploit the available data for constructive applications to benefit more than just the immediate use case and users. One prominent example is the Google keyboard (Gboard) prediction function [62], where Google improves the performance of their mobile keyboard prediction by gaining information from user interaction. This example highlights information privacy in that improvements to this technology will benefit all users, although users are only willing to contribute if their privacy is ensured. Therefore, FL techniques that exploit data and maintain user and data privacy are attractive for IoT applications [146].

In such scenarios and related domains, it is well understood that communication and computing resources are two of the bottlenecks in real-life FL applications. These devices are often used for tasks other than FL, so the FL task usually competes with these other ones for computing resources, making scheduling and coordinating even more complicated. Asynchronous strategies like PAPAYA [67] appear to address such issues. Other scenarios include heterogeneity in computing resources [43] or drift in local device clocks [78], leading to asynchrony caused by varying compute and resulting in delays in the aggregation step. Methods to account for or dynamically adapt to changing available resources will greatly enhance the utility of FL techniques in these scenarios. The increased need for bandwidth for FL iterations has led to significant research efforts in reducing it. Methods combining optimizers such as FedAvg with sparsification and/or quantization of model updates to a small number of bits have demonstrated significant reductions in communication overhead. However, it still remains an open research question on how communication overheads can be further reduced and whether any of these methods or their combinations can come close to providing optimal trade-offs between communication and accuracy. For example, the Fed-ET approach communicates using smaller models [38]. Another class of approach to maximizing bandwidth usage in FL approaches include device selection [104].

Although efforts in these situations are motivated by increasing communications efficiency, device selection methods can potentially provide device privacy in terms of revealing which nodes are contributing to the FL process. Moreover, there has also been recent work that allows control of the information exchange to limit communications, but can similarly be used to provide some privacy of node utility to FL algorithms [129].

Additionally, IoT has been promoted as a use-case for edge networks where bandwidth, storage, and compute are limited. These systems operate in a variety of environments often characterized a stringent operational requirements, despite having to cope with sophisticated adversarial influences and constraints in both computational and network resources. These environments include resource-constraints inhibiting information exchange to other nodes, specifically a central node with which centralized computation and decisions can be conducted. Federated approaches have been proposed for use in sensor networks, swarms of unmanned aerial vehicles and on coalition networks for shared situational awareness. They have also been proposed for FL at the edge by reducing the network overhead incurred by such learning processes [130]. The promise of IoT and edge computing will continue to be revealed, with FL techniques potentially being a main driver of the technologies.

5 Privacy-Related Policies

Most of the existing regulations on safeguarding consumer privacy, both nationally and internationally, were conceived in a pre-AI/ML era. Currently, they have not been able to keep up with the rapid evolution of AI/ML and their privacy implications. The General Data Protection Regulation ("GDPR") [10] from the European Union governs data protection and privacy for all citizens within the EU and imposes strict obligations on data controllers and processors. GDPR contains the *principle of data minimization* in article 5.1 (c), which requires that data which is not necessary to achieve the intended purpose cannot be collected, stored, or otherwise processed lawfully. Since FL restricts the transfer of raw data to a central location, it provides more compliance with the principle of data minimization than other approaches that require the transfer of all raw data to a central location for model training. FL also protects the collected data from unwanted processing that is not compliant with the collection purpose, satisfying the *principle of purpose limitation*, as described in article 5.1.(b).

In the United States, the state of Privacy and AI laws is tracked by the EPIC project, which shows a recent large number of states that have effective privacy laws [5]. Each of these privacy laws has specific requirements for accessing and processing personal data. Even FTC is enforcing the same privacy rights for companies using AI [9]. At the federal level, sector-specific privacy polices in the US, such as Graham-Leach-Bliley Act (GLBA) [11] for financial data or Health Insurance Portability and Accountability Act (HIPAA) [12] for medical data provide consumers with limited protection scope when it comes to using AI and ML. Recently, the US introduced H.R. 8152-The American Data Privacy and Protection Act [14]-to catch up with various amendments proposed in EU on AI/ML workloads by extending the covered algorithm to AI/ML space. Some states also patched their existing policies such as California Privacy Rights Act (CPRA) [4] amendments to the CCPA [3] or the Texas Data Privacy and Security Act (TDPSA) [16].

GenAI's remarkable capability to analyze data and perform complex analysis further amplifies privacy concerns. There are clear privacy gaps in existing privacy policies as they relate to AI systems. Most of these policies and regulations were proposed pre-AI and even newer ones pre-Gen AI where there has been less information on privacy implications of these systems. Such gaps may pose significant challenges to privacy laws and they will need further amendments to address newer emerging privacy concerns.

The recent AI Foundation Model Transparency Act [1] mandates FTC and NIST to establish standards for data sharing by foundation model deployers. This legislation aims to empower consumers to make wellinformed decisions

when they interact with AI. The Algorithmic Accountability Act of 2023 [2] also requires companies to assess the impacts of the AI systems on consumer privacy and give users choices when they interact with AI systems.

Future policy. The previous regulations mostly require keeping the data in its location and restrict its processing based on intended collection purposes. GL is a potential solution to facilitate compliance with these privacy laws. In the near future, we anticipate a growing alignment between technological advancements – especially in artificial intelligence (AI) and FL – and evolving regulatory frameworks. This alignment will likely follow several key pathways.

First, there is a need for regulation specialized for AI use cases and application domains. Rather than relying on adapting existing frameworks like GDPR or HIPAA, regulatory bodies are expected to introduce laws specifically tailored to AI. These regulations will address the entire AI model lifecycle, covering aspects such as data collection, model training, decision-making, and retraining. The goal will be to ensure greater accountability, fairness, and transparency in AI systems. Additionally, the rise of generative AI requires a stronger focus on regulating not just the input data but also the output of AI systems. Transparency around how these generative systems, including large language models, are trained, the datasets they rely on, and how their outputs might impact privacy or perpetuate or amplify biases will become increasingly important. Moreover, governments can mandate real-time monitoring and reporting tools to ensure that AI systems maintain compliance with privacy regulations as they evolve dynamically.

Second, FL is poised to emerge as a valuable tool for compliance. As its use becomes more widespread, regulators may view it as a method that aligns with privacy-by-design principles. FL could be explicitly incorporated into compliance standards, particularly those influenced by GDPR-like data minimization principles, i.e., limit the collection of personal information to what is essential for a defined objective [10]. By leveraging a decentralized approach, companies may be able to innovate while ensuring compliance with data privacy laws.

Overall, FL aligns well with privacy regulations like GDPR and HIPAA. It adheres to GDPR’s principles of data minimization and purpose limitation. By keeping sensitive data on local servers, it significantly reduces the amount of sensitive information being processed centrally. Only model updates, which are typically less sensitive than raw data, are shared with the central server. FL systems can also be designed to collect only the data necessary for the specific purpose of model training. Furthermore, individuals’ rights over their data is supported by allowing users to opt-in or opt-out of the training process at any time. This aligns well with GDPR’s emphasis on user control and consent. The decentralized nature of FL enhances data security, reducing the risk of large-scale data breaches. It embodies the principle of privacy by design which is a key requirement under GDPR.

Despite the above advantages, FL still faces some regulatory challenges. Data privacy laws differ across countries and regions, which can complicate global implementation of FL systems. Further, ensuring and demonstrating compliance across a distributed system can be complex and requires robust observability and documentation practices. The process of combining multiple models during aggregation can pose security risks, such as susceptibility to model poisoning attacks. In the next two sections, we discuss new and emerging privacy threats along with other defenses such as DP-SGD or secure aggregation which may be required to continue to protect user privacy in FL.

6 Privacy Attacks

In this section, we first discuss the leading categories of privacy attacks against FL. We summarize this, with the most significant attributes of each attack type, in Table 3.

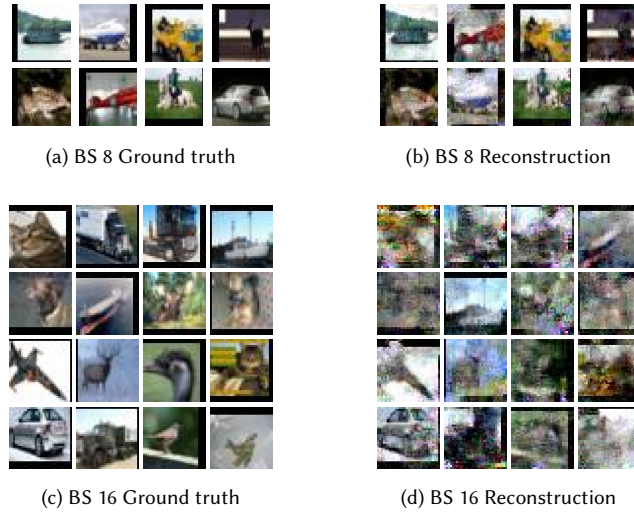


Fig. 1: Images reconstructed by Inverting Gradients [60], an optimization attack, on a batch of 8 and 16 CIFAR-10 images in FedSGD. Ground truth images (a, c) are shown on the left, and reconstructions (b, d) are shown on the right. Images are visually recognizable for batch size 8, but become less recognizable at batch size 16.

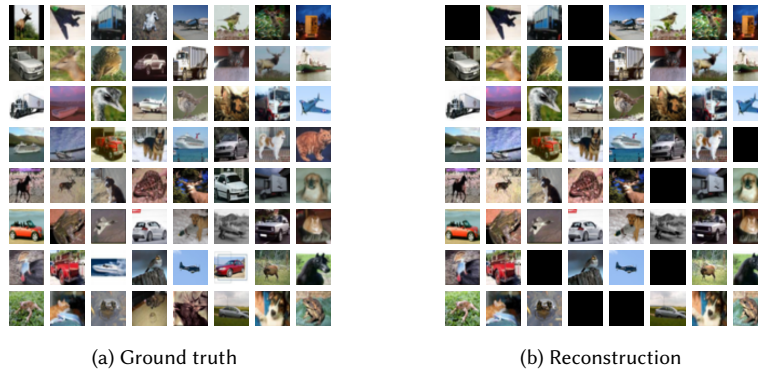


Fig. 2: Images reconstructed using LOKI [150], a linear layer leakage attack, on a batch of 64 CIFAR-10 images. FedAvg with 8 local iterations of mini-batch size 8 used. Out of 64 images, 55 are reconstructed successfully with high quality.

6.1 Data Reconstruction Attacks

6.1.1 Optimization-based. Optimization (a.k.a. gradient inversion) approaches have shown great success in leaking data from individual updates, especially with smaller batch sizes. These attacks typically operate under the threat model of an honest-but-curious server or an external attacker that has access to the model and individual gradients from each client. With only this information, the attacker initializes some dummy data (i.e., with gaussian noise) and computes the gradient of the data.

$$x^* = \arg \min_x \|\nabla L(x, y, \theta) - \nabla W\|_2 \quad (5)$$

An optimizer minimizes the difference between the generated gradient $\nabla L(x, y, \theta)$ and the ground truth gradient ∇W (benign client update). In the above equation, x is the dummy data, x^* is the reconstructed data, L is the loss function, y is the label (which can be known beforehand or solved for [147]), and θ is the model parameters.

Table 3: Summary of privacy attacks in federated learning

Attack class	Summary	Sub-category	Citation	Requirements
Data reconstruction	Attacker aims to directly reconstruct the client private data or a representation of the private data. Typically, this involves analyzing gradient updates or partial model parameters that inadvertently reveal features of the original input. With sufficient information, the attacker can refine these reconstructions to near-original fidelity, posing severe privacy risks—particularly in sensitive domains like healthcare. Factors such as model complexity, dataset size, and update granularity can further exacerbate this threat.	Gradient inversion	[60, 139, 147, 152]	Access to model and individual updates. Modification to the network parameters and/or architecture. Clients target a specific class by sending malicious updates. Varies based on attack. Attacker may modify the model parameters, know training info, or send different updates.
		Linear layer leakage	[25, 55, 150]	
		GAN-based	[66, 132]	
		Other	[80, 102, 135]	
Membership inference	Attacker infers if a sample was used in the training of the model.		[93, 98, 123, 142]	Most require access to training data from the overall distribution. Some attacks require white-box access to the model or the ability to send malicious updates.
Property inference	Attacker learns about sensitive properties within the training set (e.g., race, gender, age).		[44, 56, 58, 92]	Attacker has black-box access to the model and can access the output. They may also possess other attributes beyond the targeted one.
Model extraction	Attacker wants to steal functionality of a model. This can be the parameters, hyperparameters, etc.		[101, 126, 128]	Attacker needs black-box access to the model in order to query it and observe the outputs.

More recent optimization approaches [60, 139] work under the assumption that user labels are known prior to optimization. Typically, these labels are directly retrieved through a zero-shot solution without using optimization approaches [139, 147]. Furthermore, regularizers and strong image priors specific to image data are often used to guide optimization results [60, 63, 127, 139]. These can also result in image artifacts typical of an image class, but not in the actual training image. These approaches have shown surprising success with image data on smaller batch sizes. However, as batch sizes increase, the fraction of images recovered decreases along with the reconstruction quality and the number of iterations required for the optimization also increases. One reason stated by [152] was that regardless of the order of images in the batch, the gradient will remain the same. Having multiple possible permutations then makes the optimization more difficult. Another fundamental reason is that a larger batch size means more images and more variables for optimization. Figure 1 shows Inverting Gradients [60] reconstructions of batch size 8 and 16 on CIFAR-100, demonstrating this property of lowering quality with larger batch sizes.

Both secure aggregation and FedAvg also pose a particularly difficult challenge for optimization attacks. For secure aggregation, the aggregated updated can be thought of as large-batch consisting of the batch images from all clients. This directly exacerbates the difficulty of reconstructing larger batch sizes. FedAvg, on the other hand, adds another layer of unknowns for optimization since the intermediate model updates are unknown to the attacker. While [60] discuss attacking FedAvg, the attack is only shown with a very small local dataset size of up to 8 images on CIFAR-10. Furthermore, it needs to be investigated how different model architectures, such as transformers [64], impact the success of gradient inversion attacks.

6.1.2 Linear layer leakage. Linear layer leakage attacks are a sub-class of analytic attacks that modify FC layers to leak inputs. Using the weight and bias gradients of an FC layer to leak inputs was discussed in [51, 105]. When only a single image activates a neuron in a fully connected layer, the input to that layer can be directly reconstructed with:

$$x^i = \frac{\delta L}{\delta W^i} / \frac{\delta L}{\delta B^i} \quad (6)$$

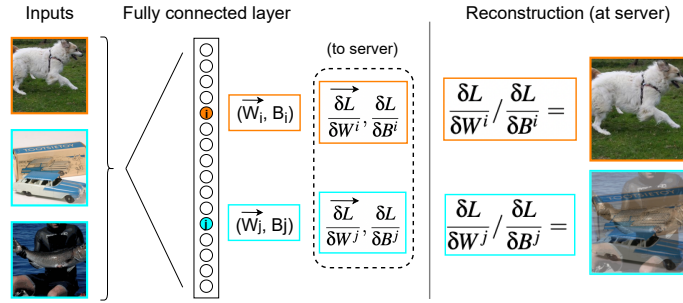


Fig. 3: Using the weight gradient $\frac{\delta L}{\delta W}$ and bias gradient $\frac{\delta L}{\delta B}$ of a fully connected layer to reconstruct the inputs. Neuron i is only activated by a single image, while j is activated by two. As a result, the reconstruction of neuron i is correct while j is a combination of images.

where i is the activated neuron, x^i is the input that activates neuron i , and $\frac{\delta L}{\delta W^i}$, $\frac{\delta L}{\delta B^i}$ are the weight gradient and bias gradient of the neuron respectively. This idea forms the basis for several reconstruction attacks [25, 55]. Figure 3 shows the basic process of leaking images through an FC layer.

When the fully-connected layer is placed at the start of a network, the data reconstructed from that layer would be the input data. This reconstruction is exact, as opposed to the optimization approaches which function as estimations. However, inputs are only reconstructed exactly when a single data sample activates that neuron. If more than one input activates the neuron, the weight and bias gradients of these inputs will contribute to the batch gradient. When the gradient division of Equation 6 is done to retrieve the input, the resulting reconstruction would be a combination of all contributing images, a case of failed attack.

To alleviate this problem, [25, 55, 150] use malicious modification of the parameters in the FC layer. For [25], trap weights were introduced, initializing the weights randomly to be half positive, half negative. In order to ensure that neuron activation is less common, the negative weights come from a larger negative magnitude range than the positive weights. They also discuss the use of convolutional layers to push the input image forward, allowing the attack to function on models starting with convolutional layers followed by fully-connected layers. However, one of the main problems of the method lies with scalability. Even if the size of the FC layer increases proportionately with an increasing total number of images, the leakage rate decreases. On the other hand, Robbing the Fed (RtF) [55] introduced another approach with higher leakage rate called “binning”, where the weights of the FC layer would measure some known continuous CDF of the input data such as image brightness. The bias for each neuron then serves as a different cutoff, allowing only inputs with a high enough value to activate it. The goal of this method would be that only one input activates each “bin”, where the bin is defined as the activated neuron with the largest cutoff (for ReLU, the largest negative bias)². For any case where only one input activates a bin, it can then be reconstructed as

$$x^i = \left(\frac{\delta L}{\delta W^i} - \frac{\delta L}{\delta W^{i+1}} \right) / \left(\frac{\delta L}{\delta B^i} - \frac{\delta L}{\delta B^{i+1}} \right) \quad (7)$$

where i is the activated bin and $i + 1$ is the bin with the next higher cutoff bias. For Equation 7 to hold true, the attack requires the use of two consecutive FC layers. The first layer is used to leak the inputs using Equation 7 and the second FC layer maintains the requirement that $\frac{\delta L}{\delta B^i}$ and $\frac{\delta L}{\delta W^i}$ are the same for any neuron that the same input activates. This is achieved by having the same weight parameters connecting each neuron of the first FC layer to the second FC layer. For example, if the first FC layer has 1024 units and the second has 256, the weights connecting them would

²The bin biases are set as negative. The weights are positive and so the negative bins are used to prevent ReLU activation.

have a dimension of 1024×256 . The above property indicates that every row of the weight matrix is equivalent, e.g. $[0, :] = [1, :] = \dots = [1023, :]$.

FedAvg. While the previous method works for FedSGD, for FedAvg, the model changes during local iterations and this prevents the reconstruction attack. As a result, Fowl et al. [55] proposed the sparse variant of the attack which uses an activation function with a double-sided threshold (e.g., Hardtanh) such as:

$$f(x) = \begin{cases} 0 & x \leq 0 \\ x & 0 \leq x \leq 1 \\ 1 & 1 \leq x \end{cases} \quad (8)$$

With this activation function, only when the input is between 0 and 1 will there be a non-zero gradient.

Using this activation function, neuron activation will be sparse (i.e., images will only activate a single neuron). However, this range between 0 and 1 for the non-zero gradient is fixed for all neurons. Since RTF's approach sets up neuron biases following a distribution of the images, the weights and biases of the FC layer will need to be adjusted to follow the new non-zero gradient range. This requires scaling the magnitude of these parameters based on the distance between the subsequent neuron biases. Consider that the weights originally measure the average pixel brightness. In this case, all weights would originally be set to $\frac{1}{N}$, where N is the total number of pixels. Then, the weights and biases are rescaled as:

$$W_i^* = \frac{W_i}{b_{i+1} - b_i}, \quad b_i^* = \frac{b_i}{b_{i+1} - b_i} \quad (9)$$

where W_i^* and b_i^* are the scaled weights and biases of neuron i , respectively, and $b_{i+1} - b_i$ is the distance between adjacent biases in the original distribution. This process uses the same distribution as the FedSGD case to setup the initial biases, while incorporating the fixed range of the new activation function by scaling the parameters. In FedAvg, after the clients send the updated model parameters, the server computes a "gradient" as:

$$\nabla W_{FedAvg} = \Theta_{t+1} - \Theta_t \quad (10)$$

where Θ is the model parameters for the securely aggregated model and ∇W_{FedAvg} the computed gradient.

This FedAvg attack [55] works well in the context of single client attacks. However, attacking secure aggregated gradients becomes a problem as the total number of images in the gradient increases multiplicatively to the number of clients. In a recent attack, Zhao et al. [150] (LOKI) finds that numerical precision poses a problem for the FedAvg linear layer leakage attack when a large number of clients are attacked. Through the use of convolutional layers and a convolutional scaling factor (CSF), LOKI is able to scale to an arbitrary number of clients while maintaining a high leakage rate. Furthermore, the CSF improves on the multiple-image reconstruction problem, only allowing images within the same local mini-batch to activate the same units. Notably, this allows the leakage rate of FedAvg attacks to *surpass* the leakage rate in FedSGD (where FedAvg is typically thought to be harder to attack than FedSGD). Figure 2 shows the reconstructions from LOKI on a total of 64 images from CIFAR-100 in FedAVG (split over 8 local iterations). LOKI achieves a high leakage rate, with $\frac{55}{64}$ images reconstructed with high quality.

Linear layer leakage reconstruction quality is typically higher quality than optimization-based attacks and is not impacted by the number of clients. However, it also requires malicious modification of the model parameters and/or architecture, resulting in more detectable attacks. Furthermore, the attack also adds a resource overhead to the total

model size. This problem is exacerbated by secure aggregation, as the size of the attack layer needs to scale to keep the attack effective. This problem along with the use of sparse tensors to alleviate it are discussed by Zhao et al. [149].

6.1.3 GAN-based. Generative networks were introduced to attack collaborative learning in [66, 132]. However, contrary to optimization-based attacks and linear layer leakage, the attack does not aim to directly reconstruct exact training images but instead reconstructs representations of a targeted class which the attacker does not hold any images of. In the attack, an adversary (a client in collaborative or federated learning training) trains a generative network in conjunction with the benign collaborative model. For a single training round, the attack process goes as follows:

- (1) The adversary downloads the model (or a portion of parameters in certain forms of collaborative training).
- (2) Images for the targeted class are generated by the generator and the generator is updated based on the discriminator (the global model).
- (3) Images for the targeted class are generated by the updated generator and mislabeled.
- (4) The adversary trains on the set of mislabeled images and any actual training images.
- (5) The adversary uploads the update to the parameter server.

Both training the generator and training on mislabeled images are critically important to the attack process. Firstly, training the generator is crucial since the ultimate goal is to be able to generate representations of a targeted class. Secondly, the process of including mislabeled generated images in order to influence the training process is also very important. Without this additional influence on training, the authors note that the generated image quality does not converge to a visible reconstruction.

One main strength of the mention is also in the ability to work through differential privacy. Specifically, the attack relies on the fact that the client model is able to learn and improve the accuracy. As long as the model is learning, the generator is also able to learn to reconstruct better images. This makes the GAN attack remarkably resilient to (at least record-level) differential privacy. As long as the privacy budget ϵ allows the model to continue learning, the attack works. When too restrictive of an ϵ is used, the attack fails but the model is also unable to learn.

Another strength of the GAN attack is that it can be employed through any malicious client as opposed to a parameter server. Optimization-based attacks require the observation of individual gradient updates along with the initial model. While clients receive the initial model state, the observation of individual gradient updates from other clients would not happen in the vanilla protocol. Linear layer leakage on the other hand can only be enacted by the server. Modification of the model parameters is required, and this can only be done by the parameter server. Compared to both these methods, only the GAN attack can be easily employed by a client. This larger attack surface also points to potentially greater privacy risks in collaborative training compared to even centralized training. It should also be noted that the attack only generates representations instead of actual reconstructions. However, this can still pose a great privacy risk depending the content of the private client training data.

6.1.4 Other attacks. While we have previously discussed the major categories of optimization, linear layer leakage, and GAN-based attacks for data reconstruction, other attacks have also been proposed that leak data differently or assist existing methods in attacking more challenging scenarios such as secure aggregation.

In order to tackle secure aggregation, a gradient suppression attack [102] was proposed whereby a malicious server sends customized model parameters to different clients such that only a single client would return a non-zero gradient

update. This attack used a dead ReLU trick where the ReLU activation functions of a layer using were set to 0.

$$\text{ReLU}(x) = \begin{cases} 0 & x \leq 0 \\ x & x > 0 \end{cases} \quad (11)$$

For a ReLU activation, any input below 0 returns a value of 0. Given the constant function when $x \leq 0$, this ultimately results in the gradients $\frac{\delta L}{\delta W} = 0$ and $\frac{\delta L}{\delta b} = 0$. Therefore, ensuring the input to the ReLU function is negative (which can be as simple as having weights w as 0 and the bias b as negative for a fully-connected layer) is a sufficient condition for achieving zeroed gradients. Using this method, a malicious server will then send a malicious model with dead-ReLUs to all clients except for a single targeted client. After secure aggregation, the aggregated update would only comprise of a single non-zero update from the targeted client allow for a single-update attack. Another work [80] aims to disaggregate the updates with the same goal of breaking aggregation. This method utilizes the additional training summary information, in particular the client participation rate, to allow the server to reconstruct the user participation matrix through observation of the aggregated updates over multiple training rounds. The attack works particularly well with a malicious server when the a fixed model is sent during each round and the clients send the same updates. When the server does not modify the training process (honest-but-curious), user participation reconstruction becomes more difficult. With a smaller batch size and a larger number of local epochs or local dataset size, reconstruction begins to fail.

In Wen et al. [135], attackers attack a target image in an arbitrarily large batch by manipulating the model parameters to magnify the update of only the single image. Magnification is done in two steps: the magnification of the target class followed by a specific feature for a target image. In order to estimate a boundary for the features, the server uses several rounds of additional FL training for setup. This requires for the batch data to be the same across training rounds. Kariyappa et al. [74] formulates the data reconstruction attack as a blind source separation problem. Given the observation that inputs to a linear layer can be directly reconstructed through the gradients, solving for the inputs is similar to solving for a unknown variables given a set of linear equations.

These attacks are all capable of breaking some levels of aggregation. [80, 102] directly break aggregation and other data reconstruction attacks to work on top of them. [74, 135] both function on individual and aggregate updates. Each of these methods have their own strengths and weaknesses. Pasquini et al. [102] requires sending different models to different clients but allows an attacker to single out a single update. Lam et al. [80] requires multiple training rounds and additional knowledge in addition to the client update. However, it can essentially disaggregate aggregate updates over time. Kariyappa et al. [74] can attack batch sizes up to 1024, but also requires malicious modification of the network parameters. Wen et al. [135] targets a single image in an arbitrary update size, but requires malicious modification of network parameters along with a few rounds of setup.

6.2 Membership Inference Attacks

The goal of membership inference attacks is to infer whether any particular data instance has been used in the training of a specific model. If a particular data instance has been used in the training, this instance is called a **member**, otherwise it is a **non-member**. Knowing the membership of one particular data point could result in revealing private information, for example, if someone's data is known to be in a cancer dataset (used to train a cancer prediction model), then it is highly likely that this particular person has cancer. Figure 4 summarizes the process of membership inference attacks.

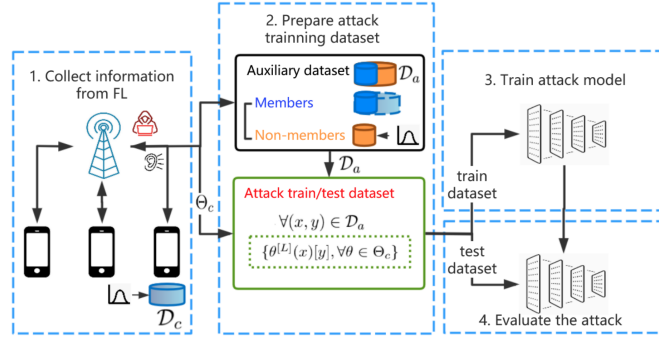


Fig. 4: Membership inference attack workflow from [142]. The attacker first collects information (e.g. parameter updates) from clients, then uses auxiliary dataset to train shadow models which can mimic the whole federated learning procedure, so that one attack model can be trained using the information collected from shadow models. Lastly, the attacker feeds the information collected from real clients into the attack model to perform membership inference attacks.

6.2.1 With access to some training data. Nasr et al. [98] presented the very first analysis of the membership inference attack against neural networks under FL with access to some training members and white-box access to trained neural networks. The adversary can be either the central server or one of the participants in the FL framework. They also presented the definition of passive attacker and active attacker, where the passive attacker does the training normally and the active attacker breaks the FL protocols to improve the effectiveness of MI attacks.

For passive attackers, they showed that attackers can take advantage of the gradients, activation maps, prediction vectors, loss, and true label of a single instance using local model of each user at different epochs during the training process and perform MI attacks. An attack model is trained using some known members.

On the other hand, two active attacker strategies were proposed. The first is the **gradient ascent attacker**, which means that the attacker will apply gradient ascent on targeted samples. By taking the action of gradient ascent, the loss of the targeted samples will increase. For member instances, their loss will be abruptly decreased by one client, thus allowing distinguishability from non-members. Both a central server adversary and a client adversary can utilize this strategy. The second active attack method is called the **isolating attacker**. The attacker can isolate one special target participant by creating a separate copy of the aggregated model. This is equivalent to training a model on a single machine using the data from the targeted client. To use this isolation attack, the adversary would be a malicious central server.

Zari et al. [142] proposed a computationally more efficient passive membership inference attack under FL which also requires some known members. Their attack uses as the feature vector the probabilities of the correct label under local models at different epochs, namely $\langle F_{\theta_{C_i}^{(1)}}(x)_y, F_{\theta_{C_i}^{(2)}}(x)_y, \dots, F_{\theta_{C_i}^{(T)}}(x)_y \rangle$, where T is the number of communication rounds. An attack model is trained to predict membership using known members and known non-members (which come from validation). Since the feature vector contains only one number from one epoch, this attack requires significantly less computational resources than the Nasr’s attack which uses information such as gradient and activation maps. The authors showed that using this probability feature vector can achieve higher membership inference attack accuracy than Nasr’s attack on CIFAR-100 dataset with AlexNet and DenseNet, but lower accuracy on Purchase dataset.

Melis et al. [93] identified membership leakage when using FL for training a word embedding function, which is a deterministic function that maps each word to a high-dimensional vector. Given a training batch (composed of sentences), the gradients are all 0’s for the words that do not appear in this batch, and thus the set of words used in

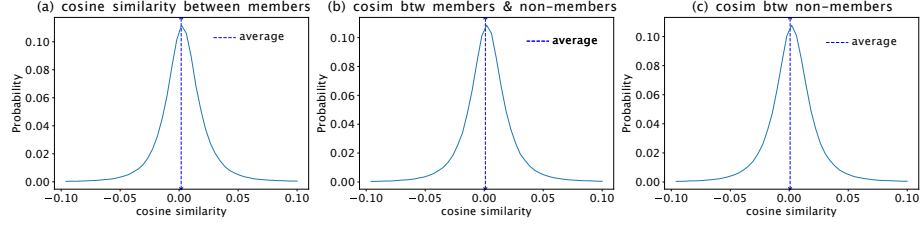


Fig. 5: Representative example of orthogonality of gradients of distinct instances (at epoch 250, AlexNet, CIFAR-100 dataset) from [83]: (a) Distribution of cosine similarity (cosim) between gradients of two distinct member instances. (b) Distribution of cosine similarity between gradients of one member instance and one non-member instance. (c) Distribution of cosine similarity between gradients of two distinct non-member instances.

the training sentences can be inferred. The attack assumes that the participants update the central server after each mini-batch, as opposed to updating after each training epoch.

6.2.2 Without access to any training data. Li et al. [83] proposed a novel membership inference attack specifically against FL *without* requiring access to private training data. The key insight is that large overparameterized neural network models usually generalize well and the gradients of large overparameterized neural network models statistically behave like high-dimensional independent isotropic random vectors (shown in Figure 5). Thus, they reformulated the task of membership inference attacks under FL as the following question: given a set of (largely unknown) orthogonal vectors, which is the parameter update coming from a particular client, does this set contain the gradients of a specific target instance?

One straightforward solution to this question is to test the cosine similarity between the gradients of the target instance and the parameter update from one particular client. If the cosine similarity is significantly higher than 0, then the attacker can claim with high confidence that this target instance is used in the training of this particular client, hence successful membership inference.

From another perspective, if $S = a + b + c$ is a sum of orthogonal vectors, then $\|S\|_2^2 - \|S - a\|_2^2 = \|a\|_2^2$, otherwise for another vector f orthogonal to a, b, c we have $\|S\|_2^2 - \|S - f\|_2^2 = -\|f\|_2^2$. These equations are easy to understand if we rotate the (orthogonal) vectors to form a canonical orthogonal basis $(a', 0, 0, \dots), (0, b', 0, \dots), (0, 0, c', \dots)$, with $a', b', c' \in \mathbb{R} \setminus \{0\}$. Each gradient vector in the sum S is now associated with a unique canonical orthogonal basis. Since the L_2 norm is invariant under basis rotations (for the same reason the length of a vector is invariant under rotation), it now becomes clear why subtracting a vector v of the orthogonal basis from S reduces the L_2 norm of S (if v is in the sum) or increases the sum's L_2 (if v is not in the sum). If the L_2 norm is reduced, the attacker could claim that the target instance is a member, otherwise it is a non-member.

6.2.3 Membership inference attacks from centralized setting. It is worth noting that all the membership inference attacks that do not require *shadow models* can be applied to FL setting as well. *Shadow models* are a commonly used technique in membership inference attacks, and allow the attacker to train models similar to the target model using data drawn from the same distribution of the training data of the target model. Thus, shadow models enable attackers to collect any information necessary for membership inference, for example, what the loss would be for one instance if this instance is not included in training.

Yeom et al. [138] presented a theoretical analysis on privacy leakage based on prediction loss. They showed that the generalization gap between training accuracy and testing accuracy could serve as a lower bound for MI attack accuracy,

as the attacker predicts the member if and only if the model's prediction is correct. Besides, they proposed a threshold attack based on prediction loss, and the attacker predicts member if and only if the prediction loss is lower than the threshold, since the loss of members is generally lower than the loss of non-members.

Inspired by Yeom et al. [138], Song et al. [123] proposed to adjust the prediction loss by a class-dependent value, noticing that some classes are harder to correctly classify than other classes. In addition, Song et al. [123] proposed using a modified prediction entropy to predict membership. The modified prediction entropy is calculated using this formula: $Mentr(F_\theta(x), y) = -(1 - F_\theta(x)_y) \log(F_\theta(x)_y) - \sum_{i \neq y} F_\theta(x)_i \log(1 - F_\theta(x)_i)$.

Jayaraman et al. [71] suggested one MI attack based on Gaussian noise. The intuition is that for a member instance, the prediction loss should increase after adding random noise. This MI attack adds multiple different random noise to the given instance and count how many times the prediction loss of the noisy instance is higher than the prediction loss of the original instance. The given instance is predicted to be a member if the count is beyond a threshold set by the attacker.

Hui et al. [68] exploits the model's prediction in a special "set" fashion. The adversary is aware of a set M of members, and N of non-members, and compute $d_1 = D(M \cup \{x\}, N)$ and $d_2 = D(M, N \cup \{x\})$, where D denotes the *Maximum Mean Discrepancy* (MMD) [54] of two distributions of features extracted from the prediction vectors. The intuition is that if x is a member, then we tend to have $d_1 > d_2$, and if x is non-member, we tend to have $d_1 < d_2$. This attack only provides predicted membership, which means that it is infeasible to evaluate its effectiveness at a low false positive rate.

6.3 Property Inference Attacks

Fredrikson et al. [56] proposed the very first black-box property inference attack where the goal is to infer sensitive attributes of a given target record which is used in the training of a target model. This black box property inference attack assumes that the adversary can obtain the model's predicted label, has knowledge of the attributes of a targeted record (including the true label) except the sensitive attribute, has access to the marginal priors of the attributes, and also to the confusion matrix of the target model (which is usually not known by the attacker). The adversary queries the target model by varying the sensitive attribute and obtains the predicted labels. Assuming that there is k different values for the single sensitive attribute that the attacker wants to know, after querying the model multiple times with k different possible values while keeping the other known attributes unchanged, the adversary computes $C(y, y') * p_i$ for each possible sensitive attribute value, where $C(y, y') = Pr[F(x) = y' | y]$ (which comes from the confusion matrix) and p_i , which is the marginal prior of i -th possible sensitive attribute value. Finally, the attack predicts the sensitive attribute value for which the $C(y, y') * p_i$ value is the maximum.

Mehnaz et al. [92] proposed two new attacks: a confidence score based model inversion attribute inference attack and a label-only model inversion attack. The key intuition of the confidence score based attack is that the target model's returned prediction is more likely to be correct and the confidence score is more likely to be higher when it is queried with a record containing the original sensitive attribute value. Thus, the value that can get correct prediction and yield lowest loss is predicted to be the correct value of the sensitive attribute. For the label-only model inversion attack, the attacker can collect a subset of target samples which satisfy the following conditions: there is only a single value of the sensitive attribute to make the prediction correct. Once this subset is successfully collected, the attacker can train an attack model to predict the value of the sensitive attribute, assuming that the collected set is always correct. They also extend the attacks to the scenario where some of the other (non-sensitive) attributes of a target record are unknown to the adversary. Moreover, they empirically demonstrate the disparate vulnerability of model inversion attacks, i.e., specific groups in the training dataset (grouped by gender, race, etc.) could be more vulnerable to model inversion

attacks. Dibbo et al. [44] refined the above method by proposing a new strategy to collect training data for the attack model. Instead of using real-world data, they proposed using random generated instances and changing the value of the sensitive attribute to query the target model. Moreover, for each random instance, it is only accepted when each different sensitive attribute results in a different predicted label. Once this random instance set is gathered, an attack model is trained to predict the sensitive attribute for instances that the attacker is interested in.

6.4 Model Extraction Attacks

In model extraction attacks [61, 100], an attacker can establish a substitute model with almost the same functionalities as the target victim model by querying the victim model. Although these attacks are not a direct threat to client data privacy in FL, they pose a threat against the server by stealing the parameters, hyper parameters, architecture, or functionality of the model [101, 126, 128]. As such, model extraction attacks serve as a privacy threat for the intellectual property (i.e., the trained model) of a company. This is a practical impediment to the widespread deployment of FL as the trained model of the server is considered a valuable asset. Hence, threats that allow an adversary to steal that asset should be defended with a high degree of certainty.

Model extraction attacks can also serve as a springboard for attacks that violate client privacy. For example, the adversary can use the proxy model created using model extraction to launch attacks that translate well to the original model. Due to the transferability property of such attacks (the attacks against the proxy model are accurate against the original model) [131], the adversary can use a membership inference attack to determine which client data items were used in creating the model. This is worrisome, as it has been recently shown that the best previous defense of perturbing the results of the query by the adversary as it is trying to construct the proxy model is still vulnerable to model extraction [33]. The basic idea is that this attack module, which can be integrated with any model extraction attack, can determine the difference in distribution between the unperturbed and perturbed query results and "reset" that difference.

7 Privacy Defenses

This section discusses the core privacy defenses in FL, which are summarized in Table 4 below.

Table 4: Summary of defenses against privacy attacks in federated learning

Defense class	Summary	Citations	Effective against	Resources
Differential privacy	Prevents privacy leakage of any individual training sample by adding noise or otherwise perturbing model updates.	[21, 46, 47, 79, 124]	Data reconstruction, membership inference (suitable for cross-silo and cross-device)	Clipping and noise added based on a privacy budget. Noise injection can be done at each client or at the aggregated-update level.
Secure aggregation	Individual updates are encrypted so the server only sees an <i>aggregate</i> update, never a single client's unencrypted data.	[23, 26, 73, 122, 151]	Data reconstruction (suitable mainly for cross-device)	Requires additional client-to-client communication for encryption masks. Typically lower overhead than homomorphic encryption.
Homomorphic encryption	Clients send encrypted updates that the server can partially operate on without decrypting. The server then returns an encrypted aggregate to clients, never seeing raw updates.	[36, 52, 143]	Data reconstruction, membership inference, property inference (suitable for cross-silo)	High communication and computation overhead for encryption/decryption. Generally more practical for cross-silo FL.

7.1 Differential Privacy

Differential Privacy (DP) [47, 48] is a widely used privacy-preserving technique. DP based defense techniques, such as DP-SGD [21], add noise to the training process. Each iteration of DP-SGD satisfies a particular (ϵ, δ) -DP guarantee through the sub-sampled Gaussian Mechanism - a composition of data sub-sampling and Gaussian noise addition. Since DP is immune to post-processing, we can compose this guarantee over multiple updates to reach a final (ϵ, δ) -DP

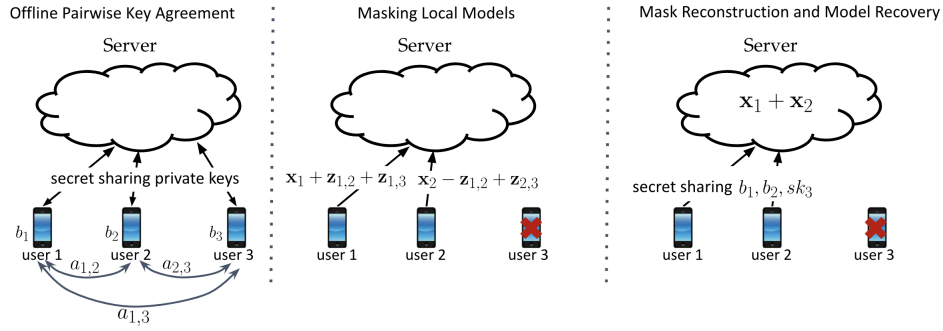


Fig. 6: An illustration of SecAgg in the example of 3 users.

guarantee. However, a naive composition—by summing the ϵ 's from each iteration would give a huge ϵ for accurate neural networks. This usually yields a trivial but not meaningful privacy guarantee. As a result, many works have proposed more sophisticated methods for analyzing the composition of DP-SGD iterations, which can prove much tighter values of $\epsilon \leq 10$ for the same algorithm [46, 79, 94]. In addition, another line of work for differential privacy based privacy auditing is also crucial to validate that the privacy guarantee is correctly deployed. The most naive method to check if privacy guarantee is enforced requires significant computational resource because even for a single instance the training needs to be reproduced multiple times in order to get enough observation to verify the privacy guarantee. Nasr et al. [97] proposed an auditing method which requires only two runs of model training and the most recent work from Steinke et al. [124] proposed one method which only requires a single run. Existing libraries such as Tensorflow privacy and Tensorflow federated [7] already provide implementations of many differential privacy based algorithms. However, practitioners should still be cautious about existing implementations and perform privacy auditing when necessary.

Limitations. DP based methods can provide a theoretical upper-bound on the effectiveness of any MI attack against any instance. However, achieving a meaningful theoretical guarantee (e.g., with a resulting $\epsilon < 5$) requires the usage of very large noises and thus results in a significant drop in accuracy. [21] gives an example for CIFAR-10 using a two convolutional layer, two linear layer network. Without differential privacy, the network can achieve 86% test accuracy. However, when $\epsilon = 2, 4, 8$ are applied, the testing accuracy drops to 67%, 70%, and 73% respectively. Larger ϵ values (less noise) result in a smaller accuracy drop and have still been shown to provide some empirical defense against MI attacks [82]. However, we once again highlight that such large values give up on the meaningful theoretical guarantees of DP-SGD.

DP-SGD also incurs additional time and space overhead. For example, in order to perform gradient clipping, one has to store per-sample gradients. Recent efforts to improve the privacy-utility tradeoff in DP-SGD, e.g., [42, 111], introduce additional computational overhead.

7.2 Secure Aggregation

Secure aggregation (SA) [26] enables the server to aggregate local model updates from a number of users, without observing any of their model updates in the clear. Specifically, SA protocols ensure that (1) the server and any set of users do not learn any information about the local dataset of any user from the encrypted model updates in the information theoretic sense; (2) the server only learns the aggregated model; (3) correct decoding of the aggregated model in the presence of user dropout.

The state-of-the-art for secure aggregation protocols in FL is to use additive masking to protect the privacy of individual models [23, 26, 73, 119, 120, 122, 151]. SecAgg [26] is the first practical protocol proposed by Google for FL that is resilient for both user failures or dropouts and collusion between users as well as the server. Particularly, SecAgg, as depicted in Figure 6, leverages pairwise random seed $a_{i,j}$, for $i, j \in [N]$, to be generated between each pair of users for masking the model updates. Each pair of users generate the pairwise random seed by using a key agreement protocol (e.g., Diffie-Hellman [45]), such that the random seed $a_{i,j}$ is a function of the public key pk_i of user i and the private key sk_j of user j . In addition, user i creates a private random seed b_i to prevent the privacy breaches that may occur if user i is only delayed rather than dropped, in which case the pairwise masks alone are not sufficient for privacy protection. For handling users failures or dropouts, the private key and the private random seed of each user are secret shared among all other users, and can be reconstructed by the server if any user drops during the protocol, which allows for a more resilient recovery protocol against user dropouts. User $i \in [N]$ then masks its model $\mathbf{x}_i$ as $\tilde{\mathbf{x}}_i = \mathbf{x}_i + \text{PRG}(b_i) + \sum_{j:i < j} \text{PRG}(a_{i,j}) - \sum_{j:i > j} \text{PRG}(a_{j,i})$, where PRG is a pseudo random generator, and sends it to the server. Finally, to remove the masks that involves the dropped users, the server asks the set of survived users for the shares of the private keys of the dropped users and the shares of the private seeds of the survived users. Figure 6 gives an example for applying SA in the FL setting of three users. The cost of constructing and sharing the masks, scales with respect to $O(N^2)$ with N corresponding to the number of users, which takes the majority of execution time.

Scalability. As the number of clients increases, defenses such as differential privacy or homomorphic encryption typically do not have a corresponding increase in the computational or communication overheads added (they are relatively fixed regardless of the number of clients). However, SA in particular has an increase in the communication costs as the number of clients in FL increase. This largely comes from the necessity of clients to communicate among themselves to ensure that the encryption works as intended (aggregation of SA encryption masks will cancel out).

One active research direction for secure aggregation in FL has been to reduce the complexity of SecAgg. In particular, SecAgg+ [23] and TruboAggregate [121] managed to reduce the quadratic complexity of SecAgg to $O(N \log N)$. TruboAggregate leverages both sequential training over groups of rings and lagrange coded computing [141], while SecAgg+ leverages a sparse random graph where each user jointly encodes its model update with only a subset of user. However, the cost of mask reconstructions in SecAgg+ still increases as more users drop, while TruboAggregate results in increasing the round/communication complexity. There have been other secure aggregation protocols proposed to reduce the computation/communication complexity of SecAgg [69, 73, 151].

Additional directions. Another interesting research direction of SA in FL has been to further analyze its formal privacy guarantees either over multi-rounds [118] or from the aggregated model [50]. In particular, while secure aggregation protocols have provable privacy guarantees at any single round, in the sense that no information is leaked beyond the aggregate model at each round, the privacy guarantees do not extend to attacks that span multiple training rounds. The authors in [118] have shown that the individual model may be reconstructed by leveraging the participation information and the aggregate models across multiple rounds.

7.3 Homomorphic Encryption

Homomorphic encryption (HE) can be considered an extension to SecAgg within FL. While SecAgg can still expose the aggregate model to the server, HE completely shields the model information from non-data owners. HE is a cryptographic technique that enables computations to be executed on encrypted data without requiring prior decryption. In essence, HE facilitates computation while preserving data in its encrypted state. This feature is essential for upholding privacy and security in contexts necessitating processing or analyzing sensitive information. Popular schemes such as CKKS

allow encrypted arithmetic on approximate numbers [36] and are therefore interesting as a solution for encrypted machine learning. With HE, computations can be conducted on encrypted data, and subsequently, the results remain interpretable upon decryption without compromising the confidentiality of the underlying data.

Clients can employ HE to encrypt their model updates within the FL paradigm before transmission. Consequently, the server exclusively receives encrypted updates and is precluded from accessing any raw model updates. Utilizing an HE protocol, the server aggregates only encrypted weights, preserving privacy. Following aggregation, the still-encrypted updated global model is sent back to the clients. Subsequently, the clients decrypt the model using their keys for further local training. HE serves to conceal each client’s contributions, thereby removing the server’s access to sensitive information. Despite the computational overhead associated with HE, its implementation can markedly enhance patient data security within collaborative learning environments.

Although HE mitigates risks such as model inversion or data leakage attributable to compromised servers, it is important to consider that the final models themselves may still retain privacy-sensitive information (see membership inference in Section 6.2). Consequently, integrating additional privacy safeguards, such as differential privacy or partial model sharing, should be considered to prevent the potential for memorization of individual training data.

Several FL frameworks implement HE-based solutions for secure federated aggregation [40, 72, 110], thereby significantly improving privacy concerns in FL. These frameworks focus on typical applications of horizontal FL and deep learning models. Other approaches include HE in vertical FL applications, such as SecureBoost [35], which aims for financial applications of XGBoost [32] and encrypted Kaplan-Meier for survival analysis in oncology and genome-wide association studies in FL settings [57].

Although HE holds great promise for enhancing the security of FL applications, its scalability is constrained due to larger ciphertext messages, which could be impractical in scenarios with limited bandwidth and computing resources. Consequently, HE has been predominantly investigated in the context of cross-silo or enterprise FL applications with fewer clients, which is particularly prevalent in industries such as healthcare and finance. Furthermore, HE offers additional potential for securing client training operations through its capability for training on encrypted data [81].

7.4 Discussions

Measurements for success. Unlike attacks, it is quite difficult to directly compare the different privacy-preserving defenses in FL with each other. For example, while all data reconstruction attacks ultimately aim to reconstruct or recover private user data, the goals of each defense in FL are inherently different. For example, secure aggregation only aims at preventing participants (including the server) from seeing individual updates while providing no guarantees beyond this. Differential privacy, on the other hand, does not encrypt individual updates but instead provides theoretical guarantees on the effectiveness of data reconstruction or membership inference attacks. In this way, there is no universal metric that can be used to directly compare the different defenses with each other. Instead, the defenses should simply be evaluated on what they are claiming to defend against (e.g., a secure aggregation method would be a failure if an attacker could simply unencrypt individual updates). When choosing different defense methods for deployment, designers should also keep in mind the differing objectives of each defense.

Maintaining success of defenses in real-world deployment is difficult. Success in deployment would be the case where user data privacy is never breached, as any breach of privacy would be a critical problem. This is especially true given the large-scale nature of cross-device FL or the extremely sensitive nature of cross-silo FL deployments (i.e., hospital or financial data). Given how crucial it is to prevent privacy problems, it is often better to rely on certifiable defenses. An example would be differential privacy, which is currently being used for Google Gboard [137].

Powerful attackers. Recent research has shown that more powerful privacy attacks are possible in FL. In this case, individual defenses may not be enough. For example, the guarantee of secure aggregation is not enough against an attacker who can scale regardless of the number of clients [150] and differential privacy alone is not enough to stop an attacker from learning a representation of the data [66]. Given knowledge of adversary capabilities, it could even be possible to decrease the efficiency of certain data reconstruction attacks by exploiting data heterogeneity [150] (current defenses work regardless of what is happening with client data heterogeneity). A more effective method against these attacks could be the use of both secure aggregation and differential privacy. However, even this combination may not be enough. If malicious clients can form a large majority of participating clients, it is still possible to single out individual updates and leak information [24]. Preventing these additional attacks will require more careful client selection or even stronger differential privacy guarantees, which can often come at the cost of model performance.

8 Looking Ahead: Important Open Questions and Solution Directions

Compared to traditional machine learning, Federated Learning (FL) provides a unique perspective on security and privacy issues. Although learning seems to be more private due to the data being held locally on the clients, at the same time, the process still opens up new avenues for attacks due to the sharing of machine learning updates. Given inherent restrictions of FL, such as client computation and communication capabilities or other drawbacks such as in model performance when using certain defenses, research will need to continue in privacy-preserving FL. As a privacy-preserving technology by design, it is essential for FL to truly preserve the privacy of user data, even more than traditional (i.e., centralized) machine learning. At the same time, given the importance of model accuracy and performance in practice, it is also essential for FL to balance the trade-off between model utility and privacy.

The topic of Federated Learning privacy is attracting a lot of interest in research, development, and deployment. We expect that for the foreseeable future there will be robust activity on this topic with the balance between research, development, and deployment shifting over time. Here are six high-level directions that will need to be pursued and answered for FL to become truly useful in practice.

- (1) *Tradeoff between utility and privacy.* Most privacy-preserving techniques in FL fall in the tradeoff space between utility of the model (how accurate is the model under benign circumstances) and the privacy afforded to the data. A prototypical example is perturbation of the gradients being reported by the clients. This can be done through differential privacy (DP). Existing solutions show that the loss in utility is sharp for reasonable levels of privacy protection [76, 96, 134]. There is work to be done in making this tradeoff more gradual. Broadly, compelling solutions in this space should be able to provide an adjustable tradeoff between these two dimensions.
- (2) *From centralization to decentralization.* The big open question is will privacy be helped by a move toward greater decentralization, away from the coordination of a central federated server. The direction of decentralized learning has seen some initial results indicating a promising answer [77, 84, 115]. However, such decentralization also brings in the vulnerability of the learning process to malicious clients [113]. The question of how to ensure security to malicious clients in such learning remains open. The challenge is how to make a solution that has inherent privacy benefits also secure to misbehaving participants.
- (3) *Regulatory and ethical compliance.* We need to be able to certify that the privacy achieved by a given solution meets a given regulation, which applies within a jurisdiction. In line with the policy and regulation discussion in Section 5, for FL to become widely adopted in some critical application domains, it would be essential to provide privacy proofs so that the systems can be certified. Such certification is difficult enough in traditional deterministic programs and more so for the stochastic programs that are the basis of FL systems. As FL systems become

more prevalent, it is also imperative to address ethical concerns and ensure transparency in the process towards regulatory compliance of AI systems. This involves understanding the implications of FL on various stakeholders, including data providers, model owners, and end users. Transparency measures should be implemented to provide visibility into how FL operates, including data usage, model training, and decision-making processes. Additionally, ethical guidelines should be established to govern the responsible development and deployment of FL systems, considering factors such as fairness, bias mitigation, and accountability. Incorporating ethical considerations and transparency measures will enhance trust in FL systems and promote their responsible use in various applications. They are a step towards compliance with emerging AI regulations, such as the EU AI act [136].

- (4) *Verification of privacy by clients.* In one major line of work [25, 55, 102, 150], we have seen that privacy can be violated by the server by sending maliciously crafted models to the clients. This triggers the question of how malicious models can be examined and detected by the clients. The comparison can be quite a daunting task because of the relative weak computing power of clients, especially mobile and embedded clients, relative to the sizes of the models. The broad question is what the stealthiness of data exfiltration attacks implies for the capability to verify manipulated models by the clients.
- (5) *Handling diverse data sources and nodes.* In FL, the data sources are often diverse in various aspects, such as kinds of data (images of different resolutions, videos of different lengths, etc.) and level of noise in the data (naturally present or adversarially introduced). It is imperative for private FL to be able to work with such diverse data sources, in line with the huge development of multimodal AI models. Another dimension of diversity comes from the nodes themselves, which can differ in computational power and communication connectivity. It is an ongoing challenge to enable FL with such diverse nodes, ensuring that FL does not bias the model in favor of well-connected nodes and thus leak more information from them.
- (6) *Scalability of privacy-preserving decentralized learning.* A prime motivation for moving toward decentralized learning is that solutions are more scalable (to a larger number of nodes and larger models) than in traditional centralized learning. However, when one interposes privacy-preserving techniques, this scalability becomes more challenging to maintain. Consider that several privacy-enhancing techniques, such as differential privacy, secure aggregation, and secure multi-party computation, which are prime tools in private FL, can introduce significant computation or communication overheads. Thus, it is an open question how ongoing advances in efficiency of these privacy-preserving techniques can be incorporated into private FL.
- (7) *Personalized FL and nonIID data.* A further challenge arises from the fact that client data in FL is typically nonIID (i.e., not identically distributed across clients), which can slow or hinder convergence in standard FL approaches. Personalized FL tackles this by allowing each client to maintain a set of local parameters reflecting its unique data distribution while still benefiting from a global shared model. This technique can significantly improve performance for clients whose data differ markedly from the overall population. However, ensuring privacy under personalization remains an open research area, especially when balancing the need for local customization with the constraints of private communication and aggregation. The tension between personalization, privacy, and efficient convergence continues to drive new methods in this space.

Each of these directions presents unique challenges that must be addressed to realize the full potential of FL while safeguarding data privacy. We look forward to a field with research advances working hand-in-hand with robust

practical implementations and strong policy, all leading to widespread use of Federated Learning in security and privacy-critical applications.

Acknowledgments

This material is based in part upon work supported by: (i) **S. Bagchi and J. Zhao**: Cisco Research, the DEVCOM ARL Army Research Office under Contract number W911NF-2020-221, and the National Science Foundation under Grant Numbers CNS-2333487 and CNS-2038986. (ii) **J. Li and N. Li**: Cisco Research and the National Science Foundation under Grant Numbers CNS-2247794 and CNS-2207204. (iii) **S. Chaterji**: DEVCOM ARL Army Research Office under Contract number W911NF-2020-221 and NSF Grant Numbers CNS-2146449 (NSF-CAREER) and CNS-2333487 (NSF-FRONTIER). The first author Joshua Zhao was supported through part of his PhD by the Andrews Fellowship. Any opinions, findings, and conclusions or recommendations expressed in this material are those of the authors and do not necessarily reflect the views of the sponsors.

References

- [1] [n. d.]. AI Foundation Model Transparency Act. ([n. d.]). https://beyer.house.gov/uploadedfiles/ai_foundation_model_transparency_act_text_118.pdf
- [2] [n. d.]. Algorithmic Accountability Act. ([n. d.]). <https://www.congress.gov/bill/116th-congress/house-bill/2231>
- [3] [n. d.]. California Consumer Privacy Act. ([n. d.]). <https://oag.ca.gov/privacy/ccpa>
- [4] [n. d.]. California Privacy Rights Act. ([n. d.]). https://leginfo.ca.gov/faces/codes_displayText.xhtml?division=3.&part=4.&lawCode=CIV&title=1.81.5
- [5] [n. d.]. EPIC Project. ([n. d.]). <https://epic.org/the-state-of-state-ai-laws-2023/#:~:text=Of%20the%20AI%2Drelated%20laws,profiling%20and%20requiring%20impact%20assessments>
- [6] [n. d.]. Federated learning may provide a solution for future digital health challenges, howpublished = <https://www.kcl.ac.uk/news/federated-learning-may-provide-a-solution-for-future-digital-health-challenges>, note = Accessed: March 25, 2025.
- [7] [n. d.]. Federated Learning with Formal Differential Privacy Guarantees. <https://blog.research.google/2022/02/federated-learning-with-formal.html>. Accessed: 2023-12-18.
- [8] [n. d.]. The federated tumor segmentation (fets) initiative. <https://www.med.upenn.edu/cbica/fets>. Accessed: March 25, 2025.
- [9] [n. d.]. FTC: AI Companies: Uphold Your Privacy and Confidentiality Commitments. ([n. d.]). <https://www.ftc.gov/policy/advocacy-research/tech-at-ftc/2024/01/ai-companies-uphold-your-privacy-confidentiality-commitments>
- [10] [n. d.]. GDPR-General Data Protection Regulation. ([n. d.]). <https://gdpr-info.eu/>
- [11] [n. d.]. Gramm-Leach-Bliley Act. ([n. d.]). <https://www.ftc.gov/business-guidance/privacy-security/gramm-leach-bliley-act>
- [12] [n. d.]. Health Insurance Portability and Accountability Act. ([n. d.]). <https://www.hhs.gov/hipaa/index.html>
- [13] [n. d.]. HealthChain consortium, howpublished = <https://www.labelia.org/en/healthchain-project>, note = Accessed: March 25, 2025.
- [14] [n. d.]. H.R.8152 - American Data Privacy and Protection Act. ([n. d.]). <https://www.congress.gov/bill/117th-congress/house-bill/8152/text>
- [15] [n. d.]. Rhino Health and the American College of Radiology Enable Privacy-Preserving Artificial Intelligence. <https://www.accesswire.com/728071/rhino-health-and-the-american-college-of-radiology-enable-privacy-preserving-artificial-intelligence>. Accessed: March 25, 2025.
- [16] [n. d.]. Texas Data Privacy and Security Act. ([n. d.]). <https://capitol.texas.gov/BillLookup/Text.aspx?LegSess=88R&Bill=HB4>
- [17] [n. d.]. Trustworthy Federated Data Analytics (TFDA). <https://tfda.hmsp.center/>. Accessed: March 25, 2025.
- [18] [n. d.]. United Nations Money Laundering Overview. ([n. d.]). <https://www.unodc.org/unodc/en/money-laundering/overview.html>
- [19] 2021. Application of Federated Learning in Predictive Maintenance to Predict Remaining Useful Life. (2021). https://ifoadatascienceresearch.github.io/assets/pdfs/FL_predictive_maintenance.pdf
- [20] Mehdi Salehi Heydar Abad, Emre Ozfatura, Deniz Gunduz, and Ozgur Ercetin. 2020. Hierarchical federated learning across heterogeneous cellular networks. In *ICASSP 2020-2020 IEEE International Conference on Acoustics, Speech and Signal Processing (ICASSP)*. IEEE, 8866–8870.
- [21] Martin Abadi, Andy Chu, Ian Goodfellow, H Brendan McMahan, Ilya Mironov, Kunal Talwar, and Li Zhang. 2016. Deep learning with differential privacy. In *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security*. ACM, 308–318.
- [22] Sean Augenstein, Andrew Hard, Lin Ning, Karan Singhal, Satyen Kale, Kurt Partridge, and Rajiv Mathews. 2022. Mixed Federated Learning: Joint Decentralized and Centralized Learning. arXiv:2205.13655
- [23] James Henry Bell, Kallista A Bonawitz, Adrià Gascón, Tancrède Lepoint, and Mariana Raykova. 2020. Secure single-server aggregation with (poly) logarithmic overhead. In *Proceedings of the 2020 ACM SIGSAC Conference on Computer and Communications Security*. 1253–1269.
- [24] Franziska Boenisch, Adam Dziedzic, Roei Schuster, Ali Shahin Shamsabadi, Ilia Shumailov, and Nicolas Papernot. 2023. Reconstructing individual data points in federated learning hardened with differential privacy and secure aggregation. In *2023 IEEE 8th European Symposium on Security and*

- Privacy (EuroS&P)*. IEEE, 241–257.
- [25] Franziska Boenisch, Adam Dziedzic, Roei Schuster, Ali Shahin Shamsabadi, Ilia Shumailov, and Nicolas Papernot. 2023. When the curious abandon honesty: Federated learning is not private. *8th IEEE European Symposium on Security and Privacy (IEEE Euro S&P)* (2023).
- [26] Keith Bonawitz, Vladimir Ivanov, Ben Kreuter, Antonio Marcedone, H Brendan McMahan, Sarvar Patel, Daniel Ramage, Aaron Segal, and Karn Seth. 2017. Practical secure aggregation for privacy-preserving machine learning. In *proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security*. 1175–1191.
- [27] Nader Bouacida and Prasant Mohapatra. 2021. Vulnerabilities in federated learning. *IEEE Access* 9 (2021), 63229–63249.
- [28] Christopher Briggs, Zhong Fan, and Peter Andras. 2020. Federated learning with hierarchical clustering of local updates to improve training on non-IID data. In *2020 International Joint Conference on Neural Networks (IJCNN)*. IEEE, 1–9.
- [29] Nicholas Carlini, Steve Chien, Milad Nasr, Shuang Song, Andreas Terzis, and Florian Tramer. 2022. Membership inference attacks from first principles. In *2022 IEEE Symposium on Security and Privacy (SP)*. IEEE, 1897–1914.
- [30] Somali Chaterji, Jinkyu Koo, Ninghui Li, Folker Meyer, Ananth Grama, and Saurabh Bagchi. 2019. Federation in genomics pipelines: techniques and challenges. *Briefings in bioinformatics* 20, 1 (2019), 235–244.
- [31] Huiqiang Chen, Tianqing Zhu, Tao Zhang, Wanlei Zhou, and Philip S Yu. 2023. Privacy and Fairness in Federated Learning: on the Perspective of Trade-off. *Comput. Surveys* (2023).
- [32] Tianqi Chen and Carlos Guestrin. 2016. XGBoost: A Scalable Tree Boosting System. In *Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining* (San Francisco, California, USA) (*KDD '16*). ACM, New York, NY, USA, 785–794. <https://doi.org/10.1145/2939672.2939785>
- [33] Yanjiao Chen, Rui Guan, Xueluan Gong, Jianshuo Dong, and Meng Xue. 2023. D-dae: Defense-penetrating model extraction attacks. In *IEEE Symposium on Security and Privacy (SP)*. IEEE, 382–399.
- [34] Yao Chen, Yijie Gui, Hong Lin, Wensheng Gan, and Yongdong Wu. 2022. Federated learning attacks and defenses: A survey. In *2022 IEEE International Conference on Big Data (Big Data)*. IEEE, 4256–4265.
- [35] Kewei Cheng, Tao Fan, Yilun Jin, Yang Liu, Tianjian Chen, Dimitrios Papadopoulos, and Qiang Yang. 2021. SecureBoost: A lossless federated learning framework. *IEEE Intelligent Systems* 36, 6 (2021), 87–98.
- [36] Jung Hee Cheon, Andrey Kim, Miran Kim, and Yongsoo Song. 2017. Homomorphic encryption for arithmetic of approximate numbers. In *Advances in Cryptology—ASIACRYPT 2017: 23rd International Conference on the Theory and Applications of Cryptology and Information Security, Hong Kong, China, December 3–7, 2017, Proceedings, Part I* 23. Springer, 409–437.
- [37] Yae Jee Cho, Gauri Joshi, and Dimitrios Dimitriadis. 2023. Local or Global: Selective Knowledge Assimilation for Federated Learning with Limited Labels. In *2023 IEEE/CVF International Conference on Computer Vision (ICCV)*. 17041–17050. <https://doi.org/10.1109/ICCV51070.2023.01567>
- [38] Yae Jee Cho, Andre Manoel, Gauri Joshi, Robert Sim, and Dimitrios Dimitriadis. 2022. Heterogeneous Ensemble Knowledge Transfer for Training Large Models in Federated Learning. In *Proceedings of the Thirty-First International Joint Conference on Artificial Intelligence, IJCAI-22*. International Joint Conferences on Artificial Intelligence Organization, 2881–2887.
- [39] European Commission, Content Directorate-General for Communications Networks, and Technology. 2019. *Ethics guidelines for trustworthy AI*. Publications Office. <https://doi.org/doi/10.2759/346720>
- [40] Francesco Cremonesi, Marc Vesin, Sergen Cansiz, Yannick Bouillard, Irene Balelli, Lucia Innocenti, Santiago Silva, Samy-Safwan Ayed, Riccardo Taiello, Laetitia Kameni, et al. 2023. Fed-BioMed: Open, Transparent and Trusted Federated Learning for Real-world Healthcare Applications. *arXiv preprint arXiv:2304.12012* (2023).
- [41] Ittai Dayan, Holger R Roth, Aoxiao Zhong, Ahmed Harouni, Amilcare Gentili, Anas Z Abidin, Andrew Liu, Anthony Beardsworth Costa, Bradford J Wood, Chien-Sung Tsai, et al. 2021. Federated learning for predicting clinical outcomes in patients with COVID-19. *Nature medicine* 27, 10 (2021), 1735–1743.
- [42] Soham De, Leonard Berrada, Jamie Hayes, Samuel L. Smith, and Borja Balle. 2022. Unlocking High-Accuracy Differentially Private Image Classification through Scale. *CoRR* abs/2204.13650 (2022).
- [43] Enmao Diao, Jie Ding, and Vahid Tarokh. 2021. Hetero{FL}: Computation and Communication Efficient Federated Learning for Heterogeneous Clients. In *International Conference on Learning Representations*.
- [44] Sayanton V Dibbo, Dae Lim Chung, and Shagufta Mehnaz. 2023. Model inversion attack with least information and an in-depth analysis of its disparate vulnerability. In *2023 IEEE Conference on Secure and Trustworthy Machine Learning (SaTML)*. IEEE, 119–135.
- [45] Whitfield Diffie and Martin Hellman. 1976. New directions in cryptography. *IEEE transactions on Information Theory* 22, 6 (1976), 644–654.
- [46] Jinshuo Dong, Aaron Roth, and Weijie J Su. 2019. Gaussian differential privacy. *arXiv preprint arXiv:1905.02383* (2019).
- [47] Cynthia Dwork. 2008. Differential privacy: A survey of results. In *International Conference on Theory and Applications of Models of Computation*. Springer, 1–19.
- [48] Cynthia Dwork, Frank McSherry, Kobbi Nissim, and Adam Smith. 2006. Calibrating noise to sensitivity in private data analysis. In *Theory of cryptography conference*. Springer, 265–284.
- [49] Ahmed El Ouadhiri and Ahmed Abdelhadi. 2022. Differential privacy for deep and federated learning: A survey. *IEEE access* 10 (2022), 22359–22380.
- [50] Ahmed Roushdy Elkordy, Jiang Zhang, Yahya H Ezzeldin, Konstantinos Psounis, and Salman Avestimehr. 2022. How much privacy does federated learning with secure aggregation guarantee? *arXiv preprint arXiv:2208.02304* (2022).

- [51] Lixin Fan, Kam Woh Ng, Ce Ju, Tianyu Zhang, Chang Liu, Chee Seng Chan, and Qiang Yang. 2020. Rethinking privacy preserving deep learning: How to evaluate and thwart privacy attacks. In *Federated Learning*. Springer, 32–50.
- [52] Haokun Fang and Quan Qian. 2021. Privacy preserving machine learning with homomorphic encryption and federated learning. *Future Internet* 13, 4 (2021), 94.
- [53] Jie Feng, Lei Liu, Qingqi Pei, and Keqin Li. 2021. Min-max cost optimization for efficient hierarchical federated learning in wireless edge networks. *IEEE Transactions on Parallel and Distributed Systems* 33, 11 (2021), 2687–2700.
- [54] Robert Fortet and Edith Mourier. 1953. Convergence de la répartition empirique vers la répartition théorique. *Annales scientifiques de l'École Normale Supérieure* 70, 3 (1953), 267–285.
- [55] Liam H Fowl, Jonas Geiping, Wojciech Czaja, Micah Goldblum, and Tom Goldstein. 2022. Robbing the Fed: Directly Obtaining Private Data in Federated Learning with Modified Models. In *International Conference on Learning Representations*.
- [56] Matt Fredrikson, Somesh Jha, and Thomas Ristenpart. 2015. Model inversion attacks that exploit confidence information and basic countermeasures. In *Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security*. 1322–1333.
- [57] David Froelicher, Juan R Troncoso-Pastoriza, Jean Louis Raisaro, Michel A Cuendet, Joao Sa Sousa, Hyunghoon Cho, Bonnie Berger, Jacques Fellay, and Jean-Pierre Hubaux. 2021. Truly privacy-preserving federated analytics for precision medicine with multiparty homomorphic encryption. *Nature communications* 12, 1 (2021), 5910.
- [58] Karan Ganju, Qi Wang, Wei Yang, Carl A Gunter, and Nikita Borisov. 2018. Property inference attacks on fully connected neural networks using permutation invariant representations. In *Proceedings of the 2018 ACM SIGSAC conference on computer and communications security*. 619–633.
- [59] Ning Ge, Guanghao Li, Li Zhang, and Yi Liu. 2021. Failure prediction in production line based on federated learning: an empirical study. *Journal of Intelligent Manufacturing* 33 (2021), 2277 – 2294. <https://api.semanticscholar.org/CorpusID:231719718>
- [60] Jonas Geiping, Hartmut Bauermeister, Hannah Dröge, and Michael Moeller. 2020. Inverting gradients-how easy is it to break privacy in federated learning? *Advances in Neural Information Processing Systems* 33 (2020), 16937–16947.
- [61] Xueluan Gong, Qian Wang, Yanjiao Chen, Wang Yang, and Xinchang Jiang. 2020. Model extraction attacks and defenses on cloud-based machine learning models. *IEEE Communications Magazine* 58, 12 (2020), 83–89.
- [62] Andrew Hard, Chloé M Kiddon, Daniel Ramage, Françoise Beaufays, Hubert Eichner, Kanishka Rao, Rajiv Mathews, and Sean Augenstein. 2018. Federated Learning for Mobile Keyboard Prediction. <https://arxiv.org/abs/1811.03604>
- [63] Ali Hatamizadeh, Hongxu Yin, Pavlo Molchanov, Andriy Myronenko, Wenqi Li, Prerna Dogra, Andrew Feng, Mona G Flores, Jan Kautz, Daguang Xu, et al. 2023. Do gradient inversion attacks make federated learning unsafe? *IEEE Transactions on Medical Imaging* (2023).
- [64] Ali Hatamizadeh, Hongxu Yin, Holger R Roth, Wenqi Li, Jan Kautz, Daguang Xu, and Pavlo Molchanov. 2022. Gradvit: Gradient inversion of vision transformers. In *Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition*. 10021–10030.
- [65] Wouter Heyndrickx, Lewis Mervin, Tobias Morawietz, Noé Sturm, Lukas Friedrich, Adam Zalewski, Anastasia Pentina, Lina Humbeck, Martijn Oldenhof, Ritsuya Niwayama, et al. 2023. Melloddy: Cross-pharma federated learning at unprecedented scale unlocks benefits in qsar without compromising proprietary information. *Journal of chemical information and modeling* (2023).
- [66] Briland Hitaj, Giuseppe Ateniese, and Fernando Perez-Cruz. 2017. Deep models under the GAN: information leakage from collaborative deep learning. In *Proceedings of the 2017 ACM SIGSAC conference on computer and communications security*. 603–618.
- [67] Dzmity Huba, John Nguyen, Kshitiz Malik, Ruiyu Zhu, Mike Rabbat, Ashkan Yousefpour, Carole-Jean Wu, Hongyuan Zhan, Pavel Ustinov, Harish Srinivas, et al. 2022. Papaya: Practical, private, and scalable federated learning. *Proceedings of Machine Learning and Systems* 4 (2022), 814–832.
- [68] Bo Hui, Yuchen Yang, Haolin Yuan, Philippe Burlina, Neil Zhenqiang Gong, and Yinzi Cao. 2021. Practical Blind Membership Inference Attack via Differential Comparisons. In *ISOC Network and Distributed System Security Symposium (NDSS)*.
- [69] Tayyeb Jahani-Nezhad, Mohammad Ali Maddah-Ali, Songze Li, and Giuseppe Caire. 2022. Swiftagg: Communication-efficient and dropout-resistant secure aggregation for federated learning with worst-case security guarantees. *arXiv preprint arXiv:2202.04169* (2022).
- [70] Pranjal Jain, Shreyas Goenka, Saurabh Bagchi, Biplob Banerjee, and Somali Chaterji. 2021. Federated action recognition on heterogeneous embedded devices. *arXiv preprint arXiv:2107.12147* (2021).
- [71] Bargav Jayaraman, Lingxiao Wang, Katherine Knipmeyer, Quanquan Gu, and David Evans. 2021. Revisiting Membership Inference Under Realistic Assumptions. *Proceedings on Privacy Enhancing Technologies* 2021, 2 (2021).
- [72] Weizhao Jin, Yuhang Yao, Shanshan Han, Carlee Joe-Wong, Srivatsan Ravi, Salman Avestimehr, and Chaoyang He. 2023. FedML-HE: An Efficient Homomorphic-Encryption-Based Privacy-Preserving Federated Learning System. *arXiv preprint arXiv:2303.10837* (2023).
- [73] Swanand Kadhe, Nived Rajaraman, O Ozan Koyluoglu, and Kannan Ramchandran. 2020. Fastsecagg: Scalable secure aggregation for privacy-preserving federated learning. *arXiv preprint arXiv:2009.11248* (2020).
- [74] Sanjay Kariyappa, Chuan Guo, Kiwan Maeng, Wenjie Xiong, G Edward Suh, Moinuddin K Qureshi, and Hsien-Hsin S Lee. 2023. Cocktail party attack: Breaking aggregation-based privacy in federated learning using independent component analysis. In *International Conference on Machine Learning*. PMLR, 15884–15899.
- [75] Mashal Khan, Frank G Glavin, and Matthias Nickles. 2023. Federated learning as a privacy solution-an overview. *Procedia Computer Science* 217 (2023), 316–325.
- [76] Muah Kim, Onur Günlü, and Rafael F Schaefer. 2021. Federated learning with local differential privacy: Trade-offs between privacy, utility, and communication. In *ICASSP 2021-2021 IEEE International Conference on Acoustics, Speech and Signal Processing (ICASSP)*. IEEE, 2650–2654.

- [77] Anastasia Koloskova, Nicolas Loizou, Sadra Boreiri, Martin Jaggi, and Sebastian Stich. 2020. A unified theory of decentralized sgd with changing topology and local updates. In *International Conference on Machine Learning*. PMLR, 5381–5393.
- [78] Jinkyu Koo, Rajesh K Panta, Saurabh Bagchi, and Luis Montestrucue. 2009. A tale of two synchronizing clocks. In *Proceedings of the 7th ACM Conference on Embedded Networked Sensor Systems (Sensys)*. 239–252.
- [79] Antti Koskela, Joonas Jälkö, and Antti Honkela. 2020. Computing tight differential privacy guarantees using fft. In *International Conference on Artificial Intelligence and Statistics*. PMLR, 2560–2569.
- [80] Maximilian Lam, Gu-Yeon Wei, David Brooks, Vijay Janapa Reddi, and Michael Mitzenmacher. 2021. Gradient disaggregation: Breaking privacy in federated learning by reconstructing the user participant matrix. In *International Conference on Machine Learning*. PMLR, 5959–5968.
- [81] Joon-Woo Lee, HyungChul Kang, Yongwoo Lee, Woosuk Choi, Jieun Eom, Maxim Deryabin, Eunsang Lee, Junghyun Lee, Donghoon Yoo, Young-Sik Kim, et al. 2022. Privacy-preserving machine learning with fully homomorphic encryption for deep neural network. *IEEE Access* 10 (2022), 30039–30054.
- [82] Jiacheng Li, Ninghui Li, and Bruno Ribeiro. 2021. Membership inference attacks and defenses in classification models. In *Proceedings of the Eleventh ACM Conference on Data and Application Security and Privacy*. 5–16.
- [83] Jiacheng Li, Ninghui Li, and Bruno Ribeiro. 2022. Effective passive membership inference attacks in federated learning against overparameterized models. In *The Eleventh International Conference on Learning Representations*.
- [84] Shuangtong Li, Tianyi Zhou, Xinmei Tian, and Dacheng Tao. 2022. Learning to collaborate in decentralized learning of personalized models. In *Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition*. 9766–9775.
- [85] Tian Li, Anit Kumar Sahu, Ameet Talwalkar, and Virginia Smith. 2020. Federated learning: Challenges, methods, and future directions. *IEEE signal processing magazine* 37, 3 (2020), 50–60.
- [86] Lumin Liu, Jun Zhang, SH Song, and Khaled B Letaief. 2020. Client-edge-cloud hierarchical federated learning. In *ICC 2020-2020 IEEE International Conference on Communications (ICC)*. IEEE, 1–6.
- [87] Lumin Liu, Jun Zhang, Shenghui Song, and Khaled B Letaief. 2022. Hierarchical federated learning with quantization: Convergence analysis and system design. *IEEE Transactions on Wireless Communications* 22, 1 (2022), 2–18.
- [88] Pengrui Liu, Xiangrui Xu, and Wei Wang. 2022. Threats, attacks and defenses to federated learning: issues, taxonomy and perspectives. *Cybersecurity* 5, 1 (2022), 1–19.
- [89] Lingjuan Lyu, Han Yu, Xingjun Ma, Chen Chen, Lichao Sun, Jun Zhao, Qiang Yang, and S Yu Philip. 2022. Privacy and robustness in federated learning: Attacks and defenses. *IEEE transactions on neural networks and learning systems* (2022).
- [90] Ashraf Mahgoub, Paul Wood, Alexander Medoff, Subrata Mitra, Folker Meyer, Somali Chaterji, and Saurabh Bagchi. 2019. {SOPHIA}: Online reconfiguration of clustered {NoSQL} databases for {Time-Varying} workloads. In *2019 USENIX Annual Technical Conference (USENIX ATC 19)*. 223–240.
- [91] Brendan McMahan, Eider Moore, Daniel Ramage, Seth Hampson, and Blaise Aguerre y Arcas. 2017. Communication-efficient learning of deep networks from decentralized data. In *Artificial intelligence and statistics*. PMLR, 1273–1282.
- [92] Shaguftha Mehnaz, Sayanton V Dibbo, Roberta De Viti, Ehsanul Kabir, Björn B Brandenburg, Stefan Mangard, Ninghui Li, Elisa Bertino, Michael Backes, Emiliano De Cristofaro, et al. 2022. Are your sensitive attributes private? Novel model inversion attribute inference attacks on classification models. In *31st USENIX Security Symposium (USENIX Security 22)*. 4579–4596.
- [93] Luca Melis, Congzheng Song, Emiliano De Cristofaro, and Vitaly Shmatikov. 2019. Exploiting unintended feature leakage in collaborative learning. In *2019 IEEE symposium on security and privacy (SP)*. IEEE, 691–706.
- [94] Ilya Mironov. 2017. Rényi differential privacy. In *2017 IEEE 30th computer security foundations symposium (CSF)*. IEEE, 263–275.
- [95] Viraaji Mothukuri, Reza M Parizi, Seyedamin Pouriyeh, Yan Huang, Ali Dehghantanha, and Gautam Srivastava. 2021. A survey on security and privacy of federated learning. *Future Generation Computer Systems* 115 (2021), 619–640.
- [96] Mohammad Naseri, Jamie Hayes, and Emiliano De Cristofaro. 2020. Local and central differential privacy for robustness and privacy in federated learning. *arXiv preprint arXiv:2009.03561* (2020).
- [97] Milad Nasr, Jamie Hayes, Thomas Steinke, Borja Balle, Florian Tramèr, Matthew Jagielski, Nicholas Carlini, and Andreas Terzis. 2023. Tight Auditing of Differentially Private Machine Learning. *arXiv preprint arXiv:2302.07956* (2023).
- [98] Milad Nasr, Reza Shokri, and Amir Houmansadr. 2019. Comprehensive privacy analysis of deep learning: Passive and active white-box inference attacks against centralized and federated learning. In *2019 IEEE symposium on security and privacy (SP)*. IEEE, 739–753.
- [99] Martijn Oldenhof, Gergely Ács, Balázs Pejő, Ansgar Schuffenhauer, Nicholas Holway, Noé Sturm, Arne Dieckmann, Oliver Fortmeier, Eric Boniface, Clément Mayer, et al. 2023. Industry-scale orchestrated federated learning for drug discovery. In *Proceedings of the AAAI Conference on Artificial Intelligence*, Vol. 37. 15576–15584.
- [100] Daryna Oliynyk, Rudolf Mayer, and Andreas Rauber. 2023. I know what you trained last summer: A survey on stealing machine learning models and defences. *Comput. Surveys* 55, 14s (2023), 1–41.
- [101] Tribhuvanesh Orekondy, Bernt Schiele, and Mario Fritz. 2019. Knockoff nets: Stealing functionality of black-box models. In *Proceedings of the IEEE/CVF conference on computer vision and pattern recognition*. 4954–4963.
- [102] Dario Pasquini, Danilo Francati, and Giuseppe Ateniese. 2022. Eluding secure aggregation in federated learning via model inconsistency. In *Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security*. 2429–2443.

- [103] Sarthak Pati, Ujjwal Baid, Maximilian Zenk, Brandon Edwards, Micah Sheller, G Anthony Reina, Patrick Foley, Alexey Gruzdev, Jason Martin, Shadi Albarqouni, et al. 2021. The federated tumor segmentation (fets) challenge. *arXiv preprint arXiv:2105.05874* (2021).
- [104] Jake Perazzone, Shiqiang Wang, Mingyue Ji, and Kevin S. Chan. 2022. Communication-Efficient Device Scheduling for Federated Learning Using Stochastic Optimization. In *IEEE INFOCOM 2022 - IEEE Conference on Computer Communications*. 1449–1458. <https://doi.org/10.1109/INFOCOM48880.2022.9796818>
- [105] Le Trieu Phong, Yoshinori Aono, Takuya Hayashi, Lihua Wang, and Shiho Moriai. 2017. Privacy-preserving deep learning: Revisited and enhanced. In *International Conference on Applications and Techniques in Information Security*. Springer, 100–110.
- [106] Muhammad Habib ur Rehman, Walter Hugo Lopez Pinaya, Parashkev Nachev, James T Teo, Sebastin Ourselin, and M Jorge Cardoso. 2023. Federated learning for medical imaging radiology. *The British Journal of Radiology* 96, 1150 (2023), 20220890.
- [107] Nicola Rieke, Jonny Hancox, Wenqi Li, Fausto Milletari, Holger R Roth, Shadi Albarqouni, Spyridon Bakas, Mathieu N Galtier, Bennett A Landman, Klaus Maier-Hein, et al. 2020. The future of digital health with federated learning. *NPJ digital medicine* 3, 1 (2020), 119.
- [108] Maria Rigaki and Sebastian Garcia. 2023. A survey of privacy attacks in machine learning. *Comput. Surveys* 56, 4 (2023), 1–34.
- [109] Holger R Roth, Ken Chang, Praveer Singh, Nir Neumark, Wenqi Li, Vikash Gupta, Sharut Gupta, Liangqiong Qu, Alvin Ihsani, Bernardo C Bizzo, et al. 2020. Federated learning for breast density classification: A real-world implementation. In *Domain Adaptation and Representation Transfer, and Distributed and Collaborative Learning: Second MICCAI Workshop, DART 2020, and First MICCAI Workshop, DCL 2020, Held in Conjunction with MICCAI 2020, Lima, Peru, October 4–8, 2020, Proceedings 2*. Springer, 181–191.
- [110] Holger R Roth, Yan Cheng, Yuhong Wen, Isaac Yang, Ziyue Xu, Yuan-Ting Hsieh, Kristopher Kersten, Ahmed Harouni, Can Zhao, Kevin Lu, et al. 2022. NVIDIA FLARE: Federated learning from simulation to real-world. *arXiv preprint arXiv:2210.13291* (2022).
- [111] Tom Sander, Pierre Stock, and Alexandre Sablayrolles. 2023. TAN Without a Burn: Scaling Laws of DP-SGD. In *International Conference on Machine Learning, ICML 2023, 23–29 July 2023, Honolulu, Hawaii, USA (Proceedings of Machine Learning Research, Vol. 202)*, Andreas Krause, Emma Brunskill, Kyunghyun Cho, Barbara Engelhardt, Sivan Sabato, and Jonathan Scarlett (Eds.). PMLR, 29937–29949.
- [112] Jonas Scherer, Marco Nolden, Jens Kleesiek, Jasmin Metzger, Klaus Kades, Verena Schneider, Michael Bach, Oliver Sedlaczek, Andreas M Bucher, Thomas J Vogl, et al. 2020. Joint imaging platform for federated clinical data analytics. *JCO clinical cancer informatics* 4 (2020), 1027–1038.
- [113] Atul Sharma, Wei Chen, Joshua Zhao, Qiang Qiu, Saurabh Bagchi, and Somali Chatterji. 2023. Flair: Defense against model poisoning attack in federated learning. In *Proceedings of the 2023 ACM Asia Conference on Computer and Communications Security*. 553–566.
- [114] Atul Sharma, Wei Chen, Joshua Zhao, Qiang Qiu, Somali Chatterji, and Saurabh Bagchi. 2021. TESSERACT: Gradient Flip Score to Secure Federated Learning Against Model Poisoning Attacks. *arXiv:2110.10108 [cs.LG]* <https://arxiv.org/abs/2110.10108>
- [115] Atul Sharma, Joshua C Zhao, Wei Chen, Qiang Qiu, Saurabh Bagchi, and Somali Chatterji. 2023. How to Learn Collaboratively-Federated Learning to Peer-to-Peer Learning and What’s at Stake. In *2023 53rd Annual IEEE/IFIP International Conference on Dependable Systems and Networks-Supplemental Volume (DSN-S)*. IEEE, 122–126.
- [116] Reza Shokri, Marco Stronati, Congzheng Song, and Vitaly Shmatikov. 2017. Membership inference attacks against machine learning models. In *2017 IEEE symposium on security and privacy (SP)*. IEEE, 3–18.
- [117] Hira Shahzadi Sikandar, Huda Waheed, Sibgha Tahir, Saif UR Malik, and Waqas Rafique. 2023. A Detailed Survey on Federated Learning Attacks and Defenses. *Electronics* 12, 2 (2023), 260.
- [118] Jinhyun So, Ramy E Ali, Başak Güler, Jiantao Jiao, and A Salman Avestimehr. 2023. Securing secure aggregation: Mitigating multi-round privacy leakage in federated learning. In *Proceedings of the AAAI Conference on Artificial Intelligence*, Vol. 37. 9864–9873.
- [119] Jinhyun So, Ramy E Ali, Basak Guler, Jiantao Jiao, and Salman Avestimehr. 2021. Securing secure aggregation: Mitigating multi-round privacy leakage in federated learning. *arXiv preprint arXiv:2106.03328* (2021).
- [120] Jinhyun So, Başak Güler, and A Salman Avestimehr. 2021. Turbo-aggregate: Breaking the quadratic aggregation barrier in secure federated learning. *IEEE Journal on Selected Areas in Information Theory* 2, 1 (2021), 479–489.
- [121] Jinhyun So, Basak Guler, and A Salman Avestimehr. 2021. Turbo-Aggregate: Breaking the Quadratic Aggregation Barrier in Secure Federated Learning. *IEEE Journal on Selected Areas in Information Theory* (2021).
- [122] Jinhyun So, Corey J Nolet, Chien-Sheng Yang, Songze Li, Qian Yu, Ramy E Ali, Basak Guler, and Salman Avestimehr. 2022. Lightsecagg: a lightweight and versatile design for secure aggregation in federated learning. *Proceedings of Machine Learning and Systems* 4 (2022), 694–720.
- [123] Liwei Song, Reza Shokri, and Prateek Mittal. 2019. Membership inference attacks against adversarially robust deep learning models. In *2019 IEEE Security and Privacy Workshops (SPW)*. IEEE, 50–56.
- [124] Thomas Steinke, Milad Nasr, and Matthew Jagielski. 2023. Privacy Auditing with One (1) Training Run. *arXiv preprint arXiv:2305.08846* (2023).
- [125] Hao Sun, Xiaoli Tang, Chengyi Yang, Zhenpeng Yu, Xiuli Wang, Qijie Ding, Zengxiang Li, and Han Yu. 2024. HiFi-Gas: Hierarchical Federated Learning Incentive Mechanism Enhanced Gas Usage Estimation. *Proceedings of the AAAI Conference on Artificial Intelligence* 38, 21 (Mar. 2024), 22824–22832. <https://ojs.aaai.org/index.php/AAAI/article/view/30317>
- [126] Florian Tramèr, Fan Zhang, Ari Juels, Michael K Reiter, and Thomas Ristenpart. 2016. Stealing machine learning models via prediction {APIs}. In *25th USENIX security symposium (USENIX Security 16)*. 601–618.
- [127] Dmitrii Usynin, Daniel Rueckert, and Georgios Kaissis. 2023. Beyond gradients: Exploiting adversarial priors in model inversion attacks. *ACM Transactions on Privacy and Security* 26, 3 (2023), 1–30.
- [128] Binghui Wang and Neil Zhenqiang Gong. 2018. Stealing hyperparameters in machine learning. In *2018 IEEE symposium on security and privacy (SP)*. IEEE, 36–52.

- [129] Shiqiang Wang, Jake Perazzone, Mingyue Ji, and Kevin S. Chan. 2023. Federated Learning with Flexible Control. In *IEEE INFOCOM 2023 - IEEE Conference on Computer Communications*. 1–10. <https://doi.org/10.1109/INFOCOM53939.2023.10229070>
- [130] Shiqiang Wang, Tiffany Tuor, Theodoros Salonidis, Kin K. Leung, Christian Makaya, Ting He, and Kevin Chan. 2019. Adaptive Federated Learning in Resource Constrained Edge Computing Systems. *IEEE Journal on Selected Areas in Communications* 37, 6 (2019), 1205–1221. <https://doi.org/10.1109/JSAC.2019.2904348>
- [131] Xiaosen Wang and Kun He. 2021. Enhancing the transferability of adversarial attacks through variance tuning. In *Proceedings of the IEEE/CVF conference on computer vision and pattern recognition*. 1924–1933.
- [132] Zhibo Wang, Mengkai Song, Zhifei Zhang, Yang Song, Qian Wang, and Hairong Qi. 2019. Beyond inferring class representatives: User-level privacy leakage from federated learning. In *IEEE INFOCOM 2019-IEEE Conference on Computer Communications*. IEEE, 2512–2520.
- [133] Zhiguo Wang, Xintong Wang, Ruoyu Sun, and Tsung-Hui Chang. 2021. Federated Semi-Supervised Learning with Class Distribution Mismatch. *CoRR* abs/2111.00010 (2021).
- [134] Kang Wei, Jun Li, Ming Ding, Chuan Ma, Howard H Yang, Farhad Farokhi, Shi Jin, Tony QS Quek, and H Vincent Poor. 2020. Federated learning with differential privacy: Algorithms and performance analysis. *IEEE Transactions on Information Forensics and Security* 15 (2020), 3454–3469.
- [135] Yuxin Wen, Jonas Geiping, Liam Fowl, Micah Goldblum, and Tom Goldstein. 2022. Fishing for user data in large-batch federated learning via gradient magnification. *International Conference on Machine Learning* (2022).
- [136] Herbert Woitschläger, Alexander Erben, Bill Marino, Shiqiang Wang, Nicholas D Lane, Ruben Mayer, and Hans-Arno Jacobsen. 2024. Federated Learning Priorities Under the European Union Artificial Intelligence Act. *arXiv preprint arXiv:2402.05968* (2024).
- [137] Zheng Xu, Yanxiang Zhang, Galen Andrew, Christopher A Choquette-Choo, Peter Kairouz, H Brendan McMahan, Jesse Rosenstock, and Yuanbo Zhang. 2023. Federated learning of gboard language models with differential privacy. *arXiv preprint arXiv:2305.18465* (2023).
- [138] Samuel Yeom, Irene Giacomelli, Matt Fredrikson, and Somesh Jha. 2018. Privacy risk in machine learning: Analyzing the connection to overfitting. In *2018 IEEE 31st Computer Security Foundations Symposium (CSF)*. IEEE, 268–282.
- [139] Hongxu Yin, Arun Mallya, Arash Vahdat, Jose M Alvarez, Jan Kautz, and Pavlo Molchanov. 2021. See through gradients: Image batch recovery via gradinversion. In *Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition*. 16337–16346.
- [140] Xuefei Yin, Yanming Zhu, and Jiankun Hu. 2021. A comprehensive survey of privacy-preserving federated learning: A taxonomy, review, and future directions. *ACM Computing Surveys (CSUR)* 54, 6 (2021), 1–36.
- [141] Qian Yu, Songze Li, Netanel Raviv, Seyed Mohammadreza Mousavi Kalan, Mahdi Soltanolkotabi, and Salman A Avestimehr. 2019. Lagrange coded computing: Optimal design for resiliency, security, and privacy. In *The 22nd International Conference on Artificial Intelligence and Statistics*. PMLR, 1215–1225.
- [142] Oualid Zari, Chuan Xu, and Giovanni Neglia. 2021. Efficient passive membership inference attack in federated learning. In *NeurIPS PriML 2021-workshop Privacy in Machine Learning*.
- [143] Chengliang Zhang, Suyi Li, Junzhe Xia, Wei Wang, Feng Yan, and Yang Liu. 2020. {BatchCrypt}: Efficient homomorphic encryption for {Cross-Silo} federated learning. In *2020 USENIX annual technical conference (USENIX ATC 20)*. 493–506.
- [144] Hongyi Zhang, Jan Bosch, and Helena Holmström Olsson. 2021. Real-time End-to-End Federated Learning: An Automotive Case Study. In *2021 IEEE 45th Annual Computers, Software, and Applications Conference (COMPSAC)*. 459–468. <https://doi.org/10.1109/COMPSAC51774.2021.00070>
- [145] Kaiyue Zhang, Xuan Song, Chenhan Zhang, and Shui Yu. 2022. Challenges and future directions of secure federated learning: a survey. *Frontiers of computer science* 16 (2022), 1–8.
- [146] Tuo Zhang, Chaoyang He, Tianhao Ma, Lei Gao, Mark Ma, and Salman Avestimehr. 2021. Federated Learning for Internet of Things. In *Proceedings of the 19th ACM Conference on Embedded Networked Sensor Systems (Coimbra, Portugal) (SenSys '21)*. Association for Computing Machinery, New York, NY, USA, 413–419. <https://doi.org/10.1145/3485730.3493444>
- [147] Bo Zhao, Konda Reddy Mopuri, and Hakan Bilen. 2020. idlg: Improved deep leakage from gradients. *arXiv preprint arXiv:2001.02610* (2020).
- [148] Joshua C Zhao, Ahaan Dabholkar, Atul Sharma, and Saurabh Bagchi. 2024. Leak and Learn: An Attacker’s Cookbook to Train Using Leaked Data from Federated Learning. In *Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition*. 12247–12256.
- [149] Joshua C Zhao, Ahmed Roushdy Elkordy, Atul Sharma, Yahya H Ezzeldin, Salman Avestimehr, and Saurabh Bagchi. 2023. The Resource Problem of Using Linear Layer Leakage Attack in Federated Learning. In *Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition*. 3974–3983.
- [150] Joshua Christian Zhao, Atul Sharma, Ahmed Roushdy Elkordy, Yahya H Ezzeldin, Salman Avestimehr, and Saurabh Bagchi. 2023. LOKI: Large-scale Data Reconstruction Attack against Federated Learning through Model Manipulation. In *2024 IEEE Symposium on Security and Privacy (SP)*. IEEE Computer Society, 30–30.
- [151] Yizhou Zhao and Hua Sun. 2022. Information theoretic secure aggregation with user dropouts. *IEEE Transactions on Information Theory* 68, 11 (2022), 7471–7484.
- [152] Ligeng Zhu, Zhijian Liu, and Song Han. 2019. Deep leakage from gradients. *Advances in neural information processing systems* 32 (2019).

Received 6 May 2024; revised 24 February 2025; accepted 4 March 2025